

Bachelor Thesis

Nsak as Framework for Scenario Based Network Security

Course of study	Bachelor of Science in Computer Science
Author	Frank Gauss (gausf1) and Lukas von Allmen (vonal3)
Advisor	Wenger Hansjürg

Version 1.0 of April 15, 2026

Abstract

One-paragraph summary of the entire study – typically no more than 250 words in length (and in many cases it is well shorter than that), the Abstract provides an overview of the study.

Contents

Abstract	ii
1. Introduction	1
1.1. Motivation	1
1.2. Predecessor Project: Project 2	1
1.3. Project Goals	1
1.3.1. Research Goals	2
1.3.2. Framework	3
1.3.3. Scenarios	5
1.3.4. Evaluation Goals	7
1.3.5. Out of Scope / Optional Feature	7
2. Related Research	9
2.1. Framework Comparison	9
2.1.1. Atomic Red Team	10
2.1.2. Caldera	11
2.1.3. Metasploit	11
2.1.4. NSAK	11
2.2. AI-Research	12
2.2.1. AI and Language Models	12
2.2.2. Model Context Protocol (MCP)	12
2.2.3. Agentic-AI	13
3. Concepts	16
3.1. Framework Resources	16
3.1.1. Device	16
3.1.2. Environment	16
3.1.3. Drill	16
3.1.4. Scenario	17
3.2. Configuration Management	17
3.2.1. Static Configuration	17
3.2.2. Runtime Configuration	18
3.2.3. Resource Configuration	18
4. Methodology	19

5. Implementation	20
5.1. Configuration Management Implementation	21
5.1.1. NSAK Configuration Management	21
5.1.2. Device Configuration Management	26
5.1.3. Scenario & Drill Configuration Management	34
5.2. Reproducible Test Environment	37
5.2.1. Network Topology	38
5.2.2. DMZ-Server	39
5.2.3. Domain Control and File Server	40
5.2.4. Workstations	40
5.2.5. Printer	41
5.2.6. Introduced Vulnerabilities	41
5.3. AI –Scenarios	42
5.3.1. AI Agent	42
5.3.2. Human Interaction Hook	42
5.3.3. Local Logging	42
5.3.4. E-Mail Altering	42
5.3.5. CLI Kill Switch	42
5.3.6. Scenario: AI Agent	42
5.3.7. Scenario: AI Reconnaissance	42
5.3.8. Scenario: AI Intrusion Detection	42
6. Evaluation	43
7. Discussion	44
8. Conclusion	45
Bibliography	46
List of Figures	48
List of Tables	49
List of Listings	50
Glossary	51
A. Project Management	52
A.1. Stakeholders	52
A.2. Agile Management Process	52
A.2.1. Issue Lifecycle:	53
A.2.2. Definition of Ready (DoR)	53
A.2.3. Definition of Done (DoD)	54

A.3. Project Structure	54
A.3.1. Milestones	54
A.3.2. Epics	58
A.3.3. Issues	58
A.4. Sprints / Iterations	58
A.4.1. Planning	58
A.5. Planning and Estimation	58
A.6. Project Roadmap	59
A.7. Sprint Ceremonies	59
A.7.1. Sprint 1: 19.02 –10.03.2026	60
A.7.2. Sprint 2: 05.03 –18.03.2026	62
A.7.3. Sprint 3: 19.03 –01.04.2026	67
A.7.4. Sprint 4: 02.04 –15.04.2026	69
A.7.5. Sprint 5: 16.04 –29.04.2026	70
A.7.6. Sprint 6: 30.04 –13.05.2026	71
A.7.7. Sprint 7: 14.05 –27.05.2026	72
A.7.8. Sprint 8: 28.05 –10.06.2026	73
A.7.9. Risk Assessment	75
A.8. Meeting Notes	80
A.8.1. Checkpoint Meeting 1: 26.02.26	80
A.8.2. Checkpoint Meeting 2: 05.03.26	80
A.8.3. Checkpoint Meeting 3: 19.03.26	82
A.8.4. Checkpoint Meeting 4: 02.04.26	83
A.8.5. Checkpoint Meeting 5: 16.04.26	84
A.8.6. Checkpoint Meeting 6: 30.04.26	84
A.8.7. Checkpoint Meeting 7: 14.05.26	84
A.8.8. Checkpoint Meeting 8: 28.05.26	84
A.8.9. Checkpoint Meeting 9: 11.06.26	84
A.9. Variant Decision: Thesis Goals	85
A.9.1. Variant 1: AI vs Manually Built Scenarios	85
A.9.2. Variant 2: Multiple Blue and Red Team Scenarios (Status Quo)	86
A.9.3. Decision	86
A.10. Variant Decision: AI Integration	87
A.10.1. Variant 1: AI-agent in NSAK	87
A.10.2. Variant 2: NSAK as MCP Server	88
A.10.3. Decision	89
A.11. Workshops	90
A.11.1. Brainstorm Scenario Selection	90
A.11.2. NSAK Scenario: Network Discovery - Red Team	92
A.11.3. NSAK Scenario: TLS Downgrade Poodle - Red Team	93
A.11.4. NSAK Scenario: Honeypot - Blue Team	96
A.11.5. NSAK Scenario: Traffic Capture - Red Team	96
A.11.6. NSAK Scenario: Intrusion Detection - Blue Team	97

A.12. Self-Hosted LLM	99
A.12.1. Hardware Setup	99
A.12.2. System Setup	99
A.12.3. Evaluation	105
A.13. Writing Quality	106
A.14. Test-Environment-Code	107
A.14.1. container-lab	107
A.14.2. Flaws and Vulnerabilities	113

1. Introduction

Computer networks are constantly exposed to evolving cyber threats ...

The *Network Swiss Army Knife (NSAK)* is a framework designed to execute orchestrated security scenarios consisting of reusable attack drills in a controlled network environment. The framework aims to support automated security testing and adversary emulation on network edge devices.

The development of the NSAK framework originates from previous project work, in which the core architecture and the basic scenario execution model were developed. This thesis builds upon this foundation and extends the framework by investigating how AI agents can support automated red and blue team scenarios.

...

1.1. Motivation

Hypothesis: Artificial Intelligence (AI) can enhance red and blue team simulations in a network environment by generating and executing scenarios within the Network Swiss Army Knife (NSAK) framework and assisting in the evaluation of detection results.

1.2. Predecessor Project: Project 2

1.3. Project Goals

For a goal to be considered **S.M.A.R.T.**, it must fulfill the following criteria:

- ▶ **Specific:** What do we want to achieve?
- ▶ **Measurable:** What are the success criteria?
- ▶ **Achievable:** How do we plan to achieve this goal?
- ▶ **Relevant:** Why is it important to achieve this goal?

Describe what we did in project 2 and what project 2 is (BFH module, possible predecessor to bachelor thesis)

- ▶ **Time-bound:** Goals categorized as *must* have to be achieved within the thesis, while *should* or *could* goals are considered optional or nice to have.

1.3.1. Research Goals

Compare Frameworks (must)

To identify the USP (unique selling point) of the NSAK framework, we will analyze and compare existing security emulation frameworks. First, relevant frameworks such as MITRE Caldera and Atomic Red Team will be identified and reviewed. Based on this analysis, the identified concepts will be compared with the architecture of the NSAK framework. The comparison will focus on how scenarios and drills are defined, how configuration and parameter handling are structured, how reusable components are organized, how automation is achieved, and which AI capabilities they provide.

The analysis and comparison will be based on the following properties:

- ▶ Concepts
- ▶ Modularity
- ▶ Configurability
- ▶ Automation
- ▶ AI Capabilities

Success criteria:

- ▶ At least two security emulation frameworks are identified and reviewed
- ▶ A matrix comparing the specified properties of the selected frameworks is created
- ▶ The USP of the NSAK framework is identified

AI Integration Research (must)

The goal of this research is to investigate how AI (artificial intelligence) can support automated security testing and adversary emulation. The research evaluates potential integration points where AI could enhance the scenario execution, automation, decision-making, and analysis capabilities of the NSAK framework.

Success criteria:

- ▶ How is AI currently used in cybersecurity automation?

- ▶ Which tasks in adversary emulation can be supported or automated by AI?
- ▶ How could AI interact with the NSAK scenarios and drills (e.g., Agents, MCP)?
- ▶ What architectural changes would be required to integrate AI into NSAK?

1.3.2. Framework

Configuration Management (must)

The goal is to extend the NSAK framework, so that scenarios and drills can expose configurable parameters to increase the flexibility of scenarios and reusability of drills. Parameters can be provided via command-line arguments or YAML Ain't Markup Language (YAML) files and are resolved by the framework into a unified run configuration used for scenario execution.

Success criteria:

- ▶ Scenarios and drills can expose configurable parameters
- ▶ The available parameters can be listed by the Command Line Interface (CLI) with the `--help` option
- ▶ Parameters can be provided via CLI arguments or YAML files
- ▶ The framework resolves the inputs into a run configuration (internal data structure).

REST API (could)

Adding a REST Application Programming Interface (API) to the NSAK framework was already proposed in the predecessor project, as it greatly enhances interoperability with other tools. The priority of this goal depends heavily on the outcome of the goal 1.3.1 and on whether we want to fulfill the goal 1.3.2, which is prioritized as “could”. If the evaluated AI integration requires a Representational State Transfer Application Programming Interface (REST API) (e.g., MCP), this goal needs to be prioritized as “must”; it will be prioritized as “could”.

Success criteria:

- ▶ A REST API specification with feature parity to the CLI is created.
- ▶ The REST API is implemented according to the specification.
- ▶ The API is documented (OpenAPI) and usable by external clients.

- ▶ The REST API remains optional and does not replace the CLI-based interaction.
- ▶ Authentication and Authorization are explicitly out of scope.

MCP Server (could)

The MCP Protocol allows the AI to interact with applications in a standardized way - and could therefore be necessary for implementing AI-based scenarios. If the outcome of the research task [1.3.1](#) highlights the necessity to specify/expose an MCP-Server to interact seamlessly with the NSAK framework, the implementation is a (must), otherwise a (could).

- ▶ A MCP-Server is specified and implemented
- ▶ Documentation how to connect to the MCP is provided.
- ▶ A form of authentication is provided.

Web GUI (could)

The goal is to design and implement a web-based graphical user interface that allows users to interact with the NSAK framework in a user-friendly way. The Web Graphical User Interface (GUI) will enable management of scenarios and drills, triggering scenario execution, and visualization of execution results and system status.

Success criteria:

- ▶ A simple Web GUI that interacts with the REST API has been implemented.
- ▶ The Web GUI displays a list of available scenarios and their states.
- ▶ The scenario's results can be viewed on the Web GUI
- ▶ Scenarios can be configured and executed via the Web GUI
- ▶ Authentication and authorization are explicitly out of scope.

1.3.3. Scenarios

AI Scenarios (must)

The goal is to implement artificial intelligence according to the result of 1.3.1 and to explore the use of AI to support red, blue, and purple team exercises in the NSAK framework. The AI will be evaluated for its potential to assist in executing attacks in a scenario and analyzing detection results. The findings will help assess how AI could enhance and coordinate red and blue team activities across a network via the NSAK device.

Success criteria:

- ▶ The AI is integrated into NSAK as a scenario or as part of the framework, depending on the result of 1.3.1.
- ▶ The AI can execute CLI or Python tools to directly or indirectly interact with the attached network.
- ▶ An operator can interact with or stop the running AI.
- ▶ The result artifacts are stored and can be presented or reused for further scenarios.

Reproducible Test Environment (must)

The goal is to design and implement a reproducible and safe test environment for the NSAK framework that enables consistent execution and evaluation of scenarios and drills. The environment should provide a stable basis for testing and comparison of manual and AI-assisted scenarios.

Success criteria:

- ▶ The test environment can be set up reproducibly using a defined configuration or setup procedure with Infrastructure as code (e.g., Ansible)
- ▶ NSAK scenarios and drills can be executed consistently within the environment.
- ▶ The environment supports both manual and AI-assisted scenarios.
- ▶ Scenario results can be collected and analyzed for evaluation purposes.

Network Discovery – Red Team (must)

The goal is to implement a reference red team scenario for network discovery within the NSAK framework. The scenario should simulate reconnaissance activities to identify hosts, services, and network characteristics, and the results should be comparable to the AI-Agent approach.

Success criteria:

- ▶ A red team network discovery scenario is implemented in the NSAK framework.
- ▶ Discovered network information is collected as artifacts.
- ▶ The scenario can be executed reproducibly within the test environment.
- ▶ The results can be compared with those generated by the AI-assisted approach.

Intrusion Detection – Blue Team (should)

The goal is to define and implement a blue team reference scenario for intrusion detection within the NSAK framework. The scenario should allow observation and evaluation of suspicious network activity to assess detection capabilities in the test environment and compare the results with those of the AI approach.

Success criteria:

- ▶ A blue-team intrusion-detection scenario is implemented in the NSAK framework.
- ▶ Detection events or alerts can be observed and documented during scenario execution.
- ▶ Detection results can be compared with results from AI-assisted scenario execution.

1.3.4. Evaluation Goals

AI Scenario Evaluation (must)

The objective is to determine the effectiveness of the AI-based scenario introduced by the goal [1.3.3](#) within the network environment defined by the goal [1.3.3](#). The evaluation will assess whether the AI scenario successfully executed the expected red and blue team activities for the provided prompts and the quality of the results.

Success criteria:

- ▶ A methodical approach for the assessment is evaluated and documented.
- ▶ The results of the AI scenario for red and blue team activity are assessed.
- ▶ There is a conclusion on the effectiveness of the AI scenario for red and blue team activities.

AI vs Engineered Scenarios (must/should)

The goal of this evaluation is to compare the quality of AI-based red (network reconnaissance) (must) and blue (network intrusion detection) (should) team scenarios with that of manually engineered scenarios.

The comparison focuses on criteria such as execution reliability, reproducibility, and coverage. The results will help determine the potential benefits and limitations of AI-supported scenarios and provide insights into how AI could enhance future versions of the NSAK framework.

Success criteria:

- ▶ A methodical approach for the comparison is evaluated and documented.
- ▶ The results of the AI scenario are compared against the respective results of the red team scenario (must)
- ▶ The results of the AI scenario are compared against the respective results of the blue team scenario (should)
- ▶ There is a conclusion on the effectiveness of the AI scenario compared to manually engineered scenarios.

1.3.5. Out of Scope / Optional Feature

At the project management meeting on 05.03.26 (see Table [A.15](#) in Appendix A.7), the initial project scope was discussed. During planning, the team proposed

using AI-based scenarios and comparing them with the implemented versions, which required reassessing certain milestones.

Running AI-based scenarios does not require a REST API or GUI. A reproducible test setup and further research are needed to properly evaluate this approach.

2. Related Research

2.1. Framework Comparison

Previous research, such as ‘SOK: A Survey of Open-Source Threat Emulators’, compares multiple types of threat emulation frameworks using both quantitative and qualitative metrics [1]. Among the evaluated frameworks, Atomic Red Team, Mitre Caldera, and Metasploit received high scores in categories as environments and operator, environment configuration and scenario execution.

In the following section, the selected frameworks are briefly introduced, and the unique selling point of the NSAK is highlighted. As a point of reference, the cybersecurity community increasingly relies on the concepts of MITRE ATT&CK, which has established itself as a standard framework in the field since its introduction in 2014 [2, 3].

The MITRE ATT&CK is a globally accessible knowledge base of adversary tactics and techniques based on real-world observations [2]. The knowledge base is structured into TTP (Tactics, Techniques, and Procedures), which are organized into 14 attack behavior groups. The TTP is getting continuously updated and extended, which helps to defend against the capabilities of threat actors.

The evaluation of the proposed frameworks is based on information obtained from official documentation [4–6] and the findings of Zilberman et al. [1].

Characteristic	Metasploit Framework	Atomic Red Team	MITRE Caldera
Primary Purpose	Exploitation and penetration testing framework	Security testing through small atomic ATT&CK tests	Automated adversary emulation platform
Relation to MITRE ATT&CK	Partial mapping via modules	Direct mapping to ATT&CK techniques	Built around ATT&CK adversary emulation
Automation Level	Medium (scripts and modules)	Low (manual execution of tests)	High (automated attack chains)
Main Functionality	Exploit development, payload delivery, post-exploitation	Execute small ATT&CK technique tests	Simulate adversary campaigns across hosts
Architecture	Modular framework with exploits, payloads, and auxiliary modules	Collection of scripts/tests organized by ATT&CK techniques	Client-server platform
Typical Use Case	Penetration testing and vulnerability validation	Detection validation and security control testing	Red team automation and purple team exercises
Difficulty Level	Medium-High	Low-Medium	Medium-High

Table 2.1.: Comparison of Metasploit, Atomic Red Team, and MITRE Caldera ([1, 4–6])

As shown in Table 2.1, the key characteristics of the frameworks differ greatly. **Atomic Red Team** provides libraries of attack scripts that implement individual Tactics, Techniques, and Procedures of MITRE ATT&CK. Each attack can be executed independently or chained together into a larger attack scenario. **Mitre Caldera** is a complex, agent-based adversary simulation tool, whereas **Metasploit** is a framework that provides exploits, payloads and auxiliary modules. Further details of the frameworks are presented in the following sections. 2.1.12.1.22.1.3

Table formatting

2.1.1. Atomic Red Team

The Atomic Red Team repository provides documentation and configuration files for each technique. For every TTP, a YAML configuration file defines the execution parameters, while an enhanced Markdown file contains a human-readable description of the attack. This documentation includes a short description of the technique, execution instructions, and additional contextual information [5].

The framework can be executed directly from the command line and provides

features such as logging, detailed error messages, and automatic prerequisite checks. If a technique cannot be executed, for example due to operating system constraints, the framework reports the issue and can optionally attempt to install the required prerequisites [5].

Zilberman et al. recommends deeper cybersecurity knowledge to use Atomic Red Team framework effectively [1]. The Open Source mentality, expandability and easily usable scripts can be a great asset for an independent framework such as the NSAK.

2.1.2. Caldera

Mitre Caldera is also built on the MITRE ATT&CK knowledge base and functions as a command-and-control center. A central server controls agents running on the target system, executes attacks called abilities, and sends the operation results back to the server. Every Ability is a single attack step built on the Tactics, Techniques, and Procedures. The framework ships with a graphical user interface and is primarily used for red team attack simulation, purple teaming, and detection engineering. The additional features, like a training plugin for educational purposes, include facts that can be configured as dynamic safe values, which can be stored and parsed in later steps [4].

With its provided interface and functionality, Caldera is most suitable as a threat emulator, offering a wide range of built-in features, including lateral movement and Command and Control (CNC) communication [1].

2.1.3. Metasploit

Metasploit is a widely used penetration testing framework for testing or attacking systems and exploiting known vulnerabilities. Metasploit follows a sequence of steps to identify a vulnerability in a target system, select a vulnerability for the attack, select an exploit that uses this vulnerability, and deliver a payload that runs on the target system. The configuration via the CLI requires knowledge of the target network and system and requires partial configuration [6, 7].

According to Zilberman et al., an operator requires extensive cybersecurity knowledge to effectively use the framework. To support the operator, the GUI “Armitage”, which is not further evaluated in this work, can be used [1].

2.1.4. NSAK

The NSAK framework, as an independent universal Network Swiss Army Knife, is not confined and can leverage, if needed, different sets of attack frameworks. An approach could be to use an AI-Enhanced Network Discovery Scenario, which

provides the necessary information to configure a Metasploit attack that leads to an attack operation in Caldera and an atomic red team detection script. Hardware-based isolation and network position provide flexibility and should help reduce the operational costs of red and blue teams by reducing simple configuration overhead [8].

2.2. AI-Research

2.2.1. AI and Language Models

Language Model (LM) describes the technique for advancing language intelligence in machines and its development history can be divided into several stages. The first stage, Statistical Language Model (SLM) emerged around the 1990s, and the basic idea is to assume, that such a model can predict the next word. But the fact that an exponential number of transition probabilities are needed, caused a lack of accuracy and led limited success.

To overcome these limitations, Neural Language Model (NLM) was introduced to learn a distributed representation of words and capture more complex patterns, leading to a major breakthrough. Building on this, the advancement of pre-trained language models Pre-trained Language model (PLM), which are first trained on large datasets and then fine-tuned for specific tasks, represented another significant development.

Building on this development, Large Language Model (LLM)s further increases the scale of PLMs by expanding parameter count and computational power [9].

In large language models, parameters are the trainable numerical values that define how the model processes input and generates output. During training, these parameters are continually adjusted to enable the model to learn patterns and language context [10]. The models most of us use today, such as ChatGPT, Claude and Gemini are pre-trained LLMs used for language inference.

These advances led to MCP, a protocol that allows tools and services to expose an interface specifically for AI. Further, the introduction of AI-agents is enabling a new level of autonomy for achieving concrete goals with LLMs. The combination of these technologies is now resulting in systems, where LLMs empower autonomous agents capable of decision-making to execute complex tasks.

2.2.2. MCP

Anthropic, a US software company focused on AI research, introduced the protocol in 2024. The MCP was introduced as an open source standard that enables AI assistants to connect to external systems, including databases, business tools,

and development environments [11]. Dynamic tool discovery and schema negotiation is helping clients and agents to access these functions in a standardized manner and allows autonomous interaction. Additionally, MCP allows information to flow in both directions, so the model can send requests, and tools can send updates or events.

This architectural approach shifts the AI integration from static toward an interoperable ecosystem of AI-enabled services. On the other hand, the flexible design and open source approach of MCP unlocks multiple novel and systematic security risks that are in need of enhanced security and governance [12].

2.2.3. Agentic-AI

Agentic Artificial Intelligence (Agentic-AI) can be understood as an advanced machine intelligence that is capable of perceiving, reasoning, and acting with a certain level of autonomy. Traditional systems and agents are more limited to executing predefined commands, whereas Agentic-AI is not restricted in this way. Due to their ability to adapt in real time, they can continuously refine their knowledge, techniques, and data. The ability to access multiple inputs, from natural language processing to sensor data, allows Artificial Intelligence Agent (AI Agent)s to develop a good understanding of their environment [13].

Multi Agent System (MAS) defines a way in which multiple specialist agent coordinate and cooperate with each other to solve a task, that would not be solvable to one agent alone.

Therefore, the agents need a form of interaction that allows them to act reactively, often through a shared mental model, which helps create a common understanding of the complex tasks to be solved. To implement a MAS efficiently, modern design principles such as encapsulation and modularity are important, which are helping to balance resource usage of the system and LLM [14]

Huang et al. provide evidence that Agentic-AI and MAS are capable of solving complex tasks across various sectors, including security and banking. However, these systems also introduce new potential vulnerabilities, both within AI Agent systems themselves and through their interactions with external environments.

The identified vulnerabilities can be categorized into two types: accidental and deliberate. Accidental vulnerabilities include software bugs, logical errors introduced by agents, hardware malfunctions, and poor data quality. Deliberate attacks, on the other hand, encompass adversarial attacks targeting LLMs, data poisoning, and model theft.

To mitigate these risks, a comprehensive framework consisting of governance mechanisms, proactive monitoring, regulatory compliance, and rigorous testing is required to ensure the secure and reliable operation of agentic systems [15].

Fazit MCP and Agentic AI

In the cybersecurity podcast Risky Business, it is mentioned that MCP is “dead”. The open-source strategy of Anthropic (2.2.2) has led to the development of multiple MCP implementations that were not designed with a strong focus on security, but rather on rapid adoption of a novel technique.

This provocative claim is based on the observation that, in order to handle the excessive MCP tooling, AI Agents may instead rely on direct access to a root shell, as it provides a more efficient way of interaction [16].

Evaluated Frameworks and MCP

Caldera uses a MCP plugin as a bridge between the model and the REST API, allowing the agent to plan and issue commands in a manner similar to a human operator.

Caldera introduces three main research areas. Firstly, a planner determines the order and selection of abilities and can dynamically construct new adversaries based on user requirements through prompt-based interaction.

Secondly, an adversary factory model is used to generate adversaries tailored to the operator’s specific use cases.

Thirdly, a forward-deployed agent is enhanced with Retrieval Augmented Generation (RAG) for Cyber Threat Intelligence (CTI), leveraging Structured Threat Information Expression (STIX)-based data to create reproducible and testable adversaries [17].

The MCP-Server, provided by **Metasploit**, enables a LLM to interact with the Metasploit Framework dynamically. The Interface covers module information (a Metasploit module is a known exploit), exploitation workflows, payload generation, session management and handler management to help manage an attack. The documentation includes a security warning that emphasizes the importance of reviewing every prompt, using a test environment, and being aware of post-exploitation commands. **Metasploit** is a powerful exploitation framework, and the simplicity that AI could bring can also harm. [18]

The **Atomic Red Team** MCP Server provides an interface that allows AI systems to access and use tests from Atomic Red Team. It enables searching, validating, and optionally executing attack techniques (e.g., based on MITRE ATT&CK). [19]

Outcome Comparison

The framework comparison highlights the difference between the NSAK and the established frameworks. Each compared framework performs a specific task in

How and why is this relevant for our thesis? how could we implement it? To which findings should we pay attention? What can we ignore for now?

Elaborate on this, because we will actually not use MCP

I think we are to focused on the term MCP now. We should speak of tool-calling, MCP is just one method for achieving this.

What about the other

a complex operation, and the NSAK device can leverage the strengths of multiple aspects of a different set of tools. Building upon these insights, the NSAK is designed to extend and integrate these capabilities into a unified and adaptable system and the change of focus to AI gets further elaborated in this thesis.

3. Concepts

3.1. Framework Resources

The NSAK framework is built around four resource types that were originally defined in “Project 2” 1.2 [8]. Each resource type has a distinct role in the framework and is stored as a YAML file in the resource library.

3.1.1. Device

A **Device** resource describes a physical or virtual machine that is capable of running the NSAK framework. It serves as the execution host for scenarios and drills and is typically deployed at a strategic network position to give it the access required for the operations it performs.

A device exposes its network configuration to the framework by declaring its interfaces and their Internet Protocol addresses in its resource YAML. As an alternative, a special device with the id “Unknown” was added, which auto discovers the hosts network configuration. This allows scenarios and drills to resolve interface names and target addresses without hardcoding network details, making the same scenario portable across different devices and network environments.

3.1.2. Environment

An **Environment** represents a specific network topology, including its infrastructure components, hosts, and services [8]. It describes the target network context in which a scenario is intended to operate. For example, a simple client-server setup over a switch, a Wireless LAN access point with connected clients, or a segmented business network.

Environments are referenced by scenarios to make explicit which network context they are designed for, helping operators select and validate the right configuration before executing an operation.

3.1.3. Drill

A **Drill** is a self-contained, reusable unit of execution with a specific, well-defined goal [8]. Its goal can be an active or passive attack step, network discovery, traffic

capture, a configuration change, or any other discrete action relevant to a red or blue team activity.

Examples of drills include Address Resolution Protocol spoofing, host discovery via Address Resolution Protocol scan, transparent Transmission Control Protocol proxying, traffic capture with T-Shark, and network configuration tasks such as enabling IP forwarding or Network Address Translation (NAT).

Each drill declares the system and Python packages it requires as well as a typed interface that lists its input arguments and return type. The return value of one drill can be consumed as the input of a subsequent drill within a scenario, enabling data to flow through a chain of execution steps.

3.1.4. Scenario

A **Scenario** describes a concrete red or blue team use case and orchestrates a sequence of drills targeted at one or more environments [8]. Where a drill is a single technical reusable and modular building block, a scenario is an implementation of a specific attack or defense operation.

Like drills, scenarios declare a typed interface with input arguments, allowing operators to parameterise a scenario at execution time via the CLI without modifying the scenario definition itself. This separation keeps scenarios reusable across different network configurations while still allowing runtime flexibility.

3.2. Configuration Management

The NSAK framework distinguishes three configuration layers, each with a different scope and lifetime. Keeping them separate avoids coupling concerns that change at different rates and makes it easier to reason about where a given piece of configuration comes from.

3.2.1. Static Configuration

The static configuration layer involves values which are specific for a deployment and are very unlikely to change after the initial provision of the NSAK device. It mainly establishes the filesystem layout that all other parts of the framework depend on. For example, where the resource library is located, where runtime data is written, and what the base directory of the installation is.

3.2.2. Runtime Configuration

The runtime configuration layer holds mutable state, which might be changed by an operator via the CLI. It is stored as a YAML file, which is currently loaded at the start of every invocation. If no configuration file exists yet, a default is created automatically on first access, so no explicit initialization step is required from the user.

3.2.3. Resource Configuration

The resource configuration layer is provided by the resource library rather than the framework core. Each resource declares its own configuration inside a YAML file stored alongside its implementation. The framework reads these files to discover and load resources at runtime.

Typed Interface Arguments

Drills and scenarios declare a typed interface in their resource configuration YAML file, that lists the arguments with an explicit type annotation and an optional default value. The framework reads these annotations at runtime and automatically generates the correct CLI options for each resource. This means that adding a new argument to a drill or scenario immediately exposes it as a typed CLI option without requiring any changes to the framework or the CLI code.

Mergeable YAML Structure

All resource YAML files follow a common structure in which resources are nested under a resource-type key (e.g. `drills:`, `scenarios:`). This structure ensures that YAML files from different parts of the library could be merged into a single in-memory data structure without key conflicts, which is a prerequisite for supporting multiple library paths and composite library configurations in the future.

4. Methodology

5. Implementation

5.1. Configuration Management Implementation

The configuration management in NSAK is organised into three distinct layers, each serving a different scope and lifetime.

The **static configuration** layer resolves fixed filesystem paths at import time. It derives all relevant paths from a single base directory, which can be overridden via an environment variable to support different deployment contexts such as Docker containers or automated test environments.

The **runtime configuration** layer holds mutable state that persists across CLI invocations. It is loaded from a YAML file on every command execution and written back whenever state changes, for example, when a different device is loaded. This layer serves as the single source of truth for any information that must be shared between separate CLI calls.

The **resource configuration** layer is defined by the resource library itself. Each resource type –devices, drills, scenarios, and environments– declares its configuration inside a YAML file stored in the library. For devices, this includes network interface assignments, while drills and scenarios additionally declare their typed argument interfaces, which the CLI uses to generate the correct command options at runtime.

5.1.1. NSAK Configuration Management

The NSAK configuration is split into two distinct layers: a static layer that resolves fixed paths at import time, and a mutable runtime layer that is persisted to disk and loaded on every invocation.

Static Configuration

The static configuration is defined in `src/nsak/core/settings.py` and shown in listing 1. It derives all relevant paths from a single `BASE_PATH`, which is either supplied via the `NSAK_BASE_PATH` environment variable or resolved automatically to the repository root at import time. `RUN_PATH` points to the `run/` directory where runtime data such as the persisted config is stored, and `LIBRARY_PATHS` holds the set of directories that are searched for resource libraries. Overriding `NSAK_BASE_PATH` is the primary mechanism to run NSAK from a different base directory, e.g. inside a Docker container or during automated testing.

This section is repeating what's already stated in the concepts chapter...

```
1 import logging
2 import os
3 from pathlib import Path
4
5 from dotenv import load_dotenv
6
7 load_dotenv(os.getenv("NSAK_ENV_FILE", None))
8
9 logger = logging.getLogger()
10
11
12 def get_base_path() -> Path:
13     """
14     Returns the default base path.
15
16     :return:
17     """
18     base_path = os.getenv("NSAK_BASE_PATH", None)
19
20     if base_path is not None:
21         return Path(base_path).absolute()
22
23     return Path(__file__).resolve().parents[3].absolute()
24
25
26 def get_run_path() -> Path:
27     """
28     Returns the run path.
29
30     :return:
31     """
32     run_path = os.getenv("NSAK_RUN_PATH", None)
33
34     if run_path is not None:
35         return Path(run_path).absolute()
36
37     return (get_base_path() / "run").absolute()
38
39
40 def get_library_paths() -> set[Path]:
41     """
42     Returns a list of library paths.
43
44     :return:
45     """
46     library_paths = set()
47
48     default_path = (BASE_PATH / "lib").absolute()
49     if default_path.exists():
50         library_paths.add(default_path)
51
52     library_path = os.getenv("NSAK_LIBRARY_PATH", None)
53     if library_path is not None:
54         library_path = Path(library_path).absolute()
```

Runtime Configuration

The runtime configuration is defined as the “Config” dataclass in `src/nsak/core/configuration` and holds all state that can change during normal operation, currently the debug flag and the active “Device”. It is persisted as a YAML file at `run/config.yaml` and loaded on every CLI invocation.

To avoid loading the configuration on import, the module-level `config` object is wrapped in a `lazy_object_proxy.Proxy`. The proxy defers the actual `Config.load()` call until the object is first accessed. Since the root CLI group imports `config` on every command invocation (listing 3), this ensures the configuration is always initialised before any command logic runs. If `run/config.yaml` does not yet exist, `Config.init()` is called automatically to create a default configuration and write it to disk, eliminating the need for manual setup on first run.

```
1 from __future__ import annotations
2
3 import dataclasses
4 import logging
5
6 from nsak.core.configuration.ai_configuration import
   ↪ AiConfiguration
7 from nsak.core.configuration.container_info import ContainerInfo
8 from nsak.core.configuration.email_configuration import
   ↪ EmailConfiguration
9 from nsak.core.device import Device
10
11 logger = logging.getLogger(__name__)
12
13
14 @dataclasses.dataclass(kw_only=True)
15 class Configuration:
16     """
17     Class for loading and saving the configuration.
18     """
19
20     from ..device.device_manager import DeviceManager
21
22     debug: bool = dataclasses.field(default=True)
23     device: Device = dataclasses.field(
24         default_factory=DeviceManager.get_default,
25     )
26     container: ContainerInfo = dataclasses.field(
27         default_factory=ContainerInfo.load,
28     )
29     email: EmailConfiguration | None = dataclasses.field(
30         default=None,
31     )
32     ai: AiConfiguration | None = dataclasses.field(default=None)
33
34     def save(self) -> None:
35         """
36         Shorthand proxy for ConfigManager save.
37         """
38         from .configuration_manager import ConfigurationManager
39
40         ConfigurationManager.save(self)
```

Listing 2: NSAK Runtime Configuration

```
1 import click
2
3 from .ai_agent import ai_agent_group
4 from .config import config_group
5 from .device import device_group
6 from .drill import drill_group
7 from .environment import environment_group
8 from .scenario import kill_all_scenarios, scenario_group
9
10
11 @click.group()
12 def cli() -> None:
13     """
14     CLI root.
15     """
16     # Load the configuration for initialization
17     from nsak.core import config # noqa
18
19
20 cli.add_command(scenario_group)
21 cli.add_command(drill_group)
22 cli.add_command(device_group)
23 cli.add_command(environment_group)
24 cli.add_command(ai_agent_group)
25 cli.add_command(config_group)
26 cli.add_command(kill_all_scenarios, name="killswitch")
```

Listing 3: NSAK CLI Initialisation

Mutations to the runtime configuration always follow the same pattern: a manager method (e.g. `DeviceManager.load()`) updates the relevant field on the `config` object and calls `config.save()` to persist the change. Custom YAML representers are registered for `IPInterface` and `PosixPath` so that these types are serialised as plain strings rather than Python-specific tags. Listing 4 shows an example of the persisted `run/config.yaml` after loading the `bananapi_r4` device.

```
1 debug: true
2 device:
3   id: bananapi_r4
4   name: BananaPI R4
5   path: <base-path>/lib/devices/bananapi_r4
6   author: vonal3@bfh.ch
7   repository: <repository-url>
8   configuration:
9     network:
10       ethernets:
11         lan1@eth0:
12           addresses:
13             10.10.10.30/24:
14               is_target: true
15               is_management: false
```

Listing 4: Persisted Runtime Configuration (run/config.yaml)

5.1.2. Device Configuration Management

In the context of “Project 2”[1.2](#), this resource type was already defined conceptually, and the BananaPI R4 was added as an example in the library under `lib/devices/bananapi_r4`. But the resource type was not actually added to the NSAK core, and to manage device configurations, we need to implement the Device resource type first.

Create New Device Resource Type

Similar to the other resource types, a YAML specification for defining devices in the library and multiple classes for representing and managing devices in the core are required. Because the existing resource YAML specifications do not allow merging YAML files, this implementation proposes a new base structure that fulfills this trait. Section [5.1.2](#) describes the necessary changes to the existing YAML specifications. The listing [5](#) shows the initial specification for a device resource, which will get extended later on with a section for configuration management.

```

1 devices:
2   <str:resource-id>:
3     id: <str:device-id>
4     name: <str:device-name>
5     description: <str:device-description>
6     author: <str:author-email>
7     repository: <str:resource-repository>

```

Listing 5: Device Resource YAML Specification

In the table 5.1 below, the required Python classes are listed and described. The classes will be located under `src/nsak/core/device` within their respective files.

Class	File Name	Description
Device	device.py	Dataclass representing a device resource at runtime, closely reflecting the YAML specification.
DeviceLoader	device_loader.py	Loads and returns Device instances from the resource library.
DeviceManager	device_manager.py	Implements business logic and exposes an API for use by the CLI.

Table 5.1.: Device Resource Classes

In “Project 2”[1.2](#), it became already clear that the described classes share a lot of boilerplate code between each other. For this reason, the base classes described in [5.1](#) were added to eliminate duplicated logic, thereby improving compliance with the Don’t Repeat Yourself principles. The classes will be located under `src/nsak/core/resource` within their respective files and the adoption of the existing classes is described in section [5.1.2](#).

Class	File Name	Description
Resource	resource.py	Base class for all resources: Scenario, Drill, Environment and Device.
ResourceLoader	resource_loader.py	Base class which handles searching and loading resources from the filesystem.
ResourceManager	resource_manager.py	Base class which defines common methods for all resource manager classes.

Table 5.2.: Resource Python Classes

To complete the integration of the device resource, the new functionality must be exposed via CLI. The available bash commands are shown in the following listing 6.

```
1 # Show usage, options and subcommands for the device resource
2 nsak device --list
3
4 # List all devices found in the resource library
5 nsak device list
6
7 # Output:
8 › nsak device list
9 ID           NAME           PATH
10 bananapi_r4  BananaPI R4  <repository>/lib/devices/bananapi_r4
```

Listing 6: NSAK CLI: List Devices

Device Configuration Management Implementation

To allow a device to expose its configuration options, the YAML specification needs to be extended accordingly. For now, the focus is only on network configuration, as this is the most important information for the scenarios and drills. The specification was designed so that other sections can be added later. The following excerpt 7 shows the specification for the configuration section of the device resource YAML.

```
1 devices:
2   <str:resource-id>:
3     # ...
4     configuration:
5       network:
6         ethernets:
7           <str:interface-name>:
8             addresses:
9               <str:cidr>:
10                is_target: <boolean>
11                is_management: <boolean>
```

Listing 7: Device Resource Configuration YAML Specification

The following code snippet, located under `src/nsak/core/device/device_loader.py` 8 shows how the YAML configuration gets parsed to the respective datastructures

defined in `src/nsak/core/network/configuration.py` and `src/nsak/core/device/device.py`.

```

20 class DeviceLoader(ResourceLoader[Device]):
21     """
22     Finds and loads devices from the library paths.
23     """
24
25     ResourceClass = Device
26
27     @classmethod
28     def _parse_device_configuration(
29         cls, data: dict[str, Any]
30     ) -> DeviceConfiguration | None:
31         if "configuration" not in data:
32             return None
33         network = data["configuration"].get("network") or {}
34         if network == "auto":
35             ethernets = {}
36             for interface in get_network_interfaces():
37                 ethernets[interface.name] = {
38                     "addresses": {
39                         ip: {
40                             "is_target": True,
41                             "is_management": False,
42                         }
43                         for ips in interface.ips.values()
44                         for ip in ips
45                     }
46                 }
47         else:
48             ethernets = network.get("ethernets") or {}
49
50         return DeviceConfiguration(
51             raw=data["configuration"],
52             network=NetworkConfiguration(
53                 ethernets={
54                     interface: EthernetConfiguration(
55                         name=interface,
56                         addresses={
57                             ip: IPConfiguration(
58                                 ip=ip_interface(ip),
59
60                                 ↪ is_target=address.get("is_target",
61                                 ↪ False),
62
63                                 ↪ is_management=address.get("is_management",
64                                30 ↪ False),
65                             )
66                             for ip, address in
67                                 ↪ ethernet.get("addresses",
68                                 ↪ {}).items()
69                         },
70                     ),
71                 }
72             )
73         for interface, ethernet in ethernets.items()
74     )
75

```

```
12 @dataclasses.dataclass(frozen=True, kw_only=True)
13 class IPConfiguration:
14     """
15     Represents an ip configuration on an interface.
16     """
17
18     ip: IPInterface
19     is_target: bool
20     is_management: bool
21
22
23 @dataclasses.dataclass(frozen=True, kw_only=True)
24 class EthernetConfiguration:
25     """
26     Represents an ethernet node.
27     """
28
29     name: str
30     addresses: dict[str, IPConfiguration]
31
32
33 @dataclasses.dataclass(frozen=True, kw_only=True, eq=True)
34 class DeviceConfiguration:
35     """
36     Represents the device configuration.
37     """
38
39     raw: object
40     network: NetworkConfiguration
41
42
43 @dataclasses.dataclass(frozen=True, kw_only=True, eq=True)
44 class Device(Resource):
45     """
46     Represents a device.
47     """
48
49     NAME = "device"
50     KEY = "devices"
51
52     id: str
53     name: str
54     description: str
55     path: Path
56     author: str
57     repository: str
58     configuration: DeviceConfiguration | None = None
```

Listing 9: Device Configuration Datastructures

The following listing shows the newly available CLI commands for managing device configurations [10](#):

```
1 # List all subcommands for the Device resource
2 nsak device --help
3
4 # List all available devices
5 nsak device list
6
7 # Show the device details and configuration
8 nsak device show <str:device-id>
9
10 # Load a device into in the NSAK configuration
11 nsak device load <str:device-id>
12
13 # Show the currently loaded device stored in the NSAK
14   ↪ configuration
15 nsak device loaded
16
17 # Reset the loaded device
18 nsak device unload
```

Listing 10: Device Configuration CLI Management

Refactor Existing Resources

The implementation of the device resource [5.1.2](#) introduced an improved base structure for the resource YAML specifications and three base classes which are abstracting the common structure and functionality. This section describes the resulting changes in the existing code and resource YAML specifications.

As already stated in section [5.1.2](#) all resource type specific classes were refactored to inherit from their respective base classes as described in table [5.1](#). With the example of the `EnvironmentLoader`, the diff below [5.1](#) illustrates how the abstraction of common properties and methods allows for the removal of a lot of boilerplate code.

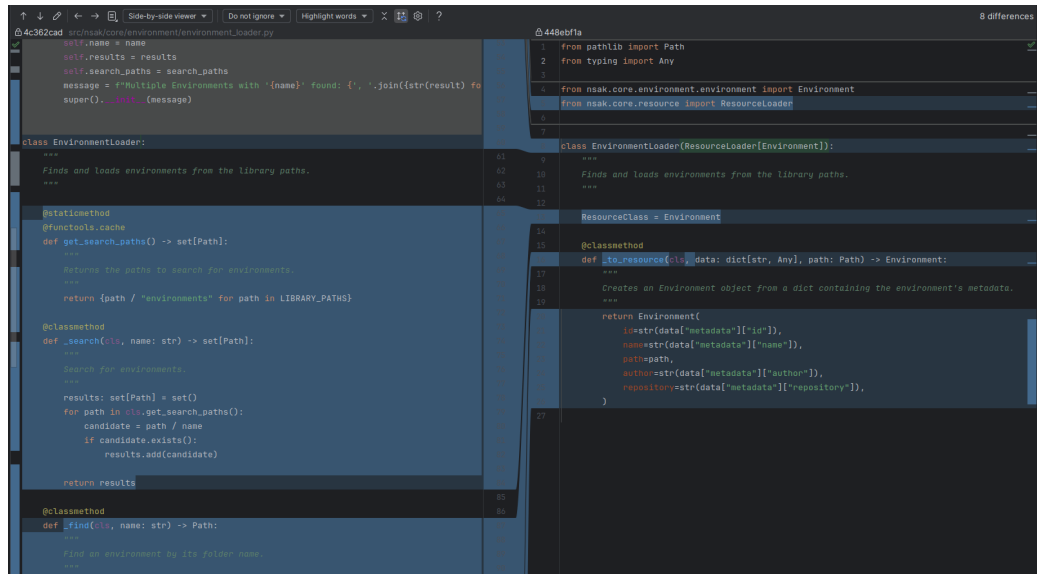


Figure 5.1.: EnvironmentLoader Base Class Refactoring Diff

The structure of all resources was aligned by nesting the resource under their respective resource type key (scenarios, drills, environments, and devices), so that we could merge all YAML resource files into a single library data structure without key conflicts. In the YAML specification [11](#) below, the new base structure derived from the device resource [5.1.2](#) is illustrated. All existing resource YAML files in the library were adjusted accordingly, and thanks to the introduction of the ResourceLoader base class, the required adjustments in the code were minimal.

```
1 # Resource type version was removed, as it was not used anyway
2
3 # scenarios|drills|environments|devices
4 <str:resource-type-key>:
5     # unique resource identifier
6     <str:resource-id>:
7         # The "metadata" key is removed and the children are now
8         ↪ nested directly under the resource
9         name: <str:name>
10        description: <str:description>
11        author: <str:email>
12        repository: <str:link>
13        # ... resource type specific properties, which
14        ↪ previously were at the top level
```

Listing 11: Mergeable Resource YAML Specification

5.1.3. Scenario & Drill Configuration Management

Both the scenario and drill resource types were already fully implemented in “Project 2”[1.2](#). Their YAML specifications already contained an interface section describing argument and return types, but this information was purely documentary and had no effect at runtime.

As part of this project, the `interface.arguments` section was extended [12](#) so that each argument carries an explicit `type` annotation and an optional default value.

```
1 <str:resource-type-key>:
2     <str:resource-id>:
3         # Unchanged properties...
4
5     interface:
6         arguments:
7             <str:argument-name>:
8                 type: <str:type-annotation>
9                 default: <any:default-value>
10        return_type: <str:type-annotation>
```

Listing 12: Updated Interface Specification

The CLI reads these annotations at runtime to generate typed command options

for each drill and scenario automatically, without requiring any additional hand-written code. The `discover_hosts` drill in listing 13 illustrates this: its single interface argument of type `str` is translated directly into a `--interface` option on the generated CLI command.

```
1 drills:
2   discover_hosts:
3     name: Discover Hosts
4     author: vonal3@bfh.ch
5     repository:
6       ↪ https://gitlab.ti.bfh.ch/gausf1-vonal3/swiss-army-knife-network-sniffe
7
8     dependencies:
9       system:
10        - arp-scan
11       python: [ ]
12
13     interface:
14       arguments:
15         interface:
16           type: str
17       return_type: NetworkDiscoveryResultMap
```

Listing 13: `discover_hosts` Drill YAML

Scenarios follow the same interface convention and additionally declare the drills and environments they depend on. The `mitm` scenario in listing 14 chains the `discover_hosts`, `arp_spoof`, and `transparent_tcp_proxy` drills together and exposes a single typed interface argument, which the CLI surfaces in the same way as for individual drills.

```
1 scenarios:
2   mitm:
3     id: mitm
4     name: MITM Scenario
5     author: vonal3@bfh.ch
6     repository:
7       ↪ https://gitlab.ti.bfh.ch/gausf1-vonal3/swiss-army-knife-network-sniffer
8
9     drills:
10       - discover_hosts
11       - arp_spoof
12       - transparent_tcp_proxy
13
14     environments:
15       - simple_tcp_client_server
16
17     dependencies:
18       system:
19         - arp-scan
20         - dsniff
21         - iptables
22       python:
23         - scapy
24
25     interface:
26       arguments:
27         interface:
28           type: str
29       return_type: None
```

Listing 14: mitm Scenario YAML

5.2. Reproducible Test Environment

Unless stated otherwise, all referenced implementation artifacts in this section originate from the NSAK repository [8].

The scope of this thesis is confined to the AI based reconnaissance and optionally, the intrusion detection scenarios A.3.1, including the design and implementation of corresponding drills.

To ensure a controlled and safe evaluation of the implementation, a simulated test environment has to be established. This approach prevents unintended interference with production systems and ensures reproducibility during the development and testing phases.

For this exact purpose the “Environment”3.1.2 resource type was implemented into the NSAK framework. In the predecessor project 1.2, a simplified network topology comprising a client (Alice) and a server (Bob) is used to emulate and analyze a Man In The Mittle (MITM) scenario. This environment is described in a Docker Compose file, located under: `lib/environments/simple_tcp_client_server/compose.yaml`.

The whole setup can be simulated with the following command: `nsak environment simulate simple_tcp_client_server mitm`.

...

While Docker or Podman provides a general-purpose containerization platform, they abstract away most of the lower levels of the network stack and thus lack the support for modeling network topologies. In the existing implementation this was partially addressed, by using the `macvlan` network driver, to enable level 2 networking. In contrast, Containerlab builds upon Docker Compose and optimize its functionalities for networking purposes.

The primary advantages of Containerlab are:

- ▶ It’s ability to create a reproducible containerized network topology based on a simple configuration file
- ▶ Support multiple interfaces nodes which closely resemble real-world network devices (in comparison Docker typically operates with a single network interface).
- ▶ The rapid creation, extension and teardown of complete network environments, ensure that each experiment starts from a clean and controlled state.

In summary, while OCI containers serves as the underlying container engine, Containerlab provides a higher-level network simulation.

The following listing 15 shows an excerpt of a Containerlab topology.yaml file. Basically the nodes are defined and with virtual Ethernet links connected. The

Maybe it would make sense to describe this in the project 2 section instead

bridge represents a multi port switch.

```
1 topology:
2   nodes:
3     node1:
4       kind: linux
5       image: alpine:3.19
6       cap-add:
7         - NET_ADMIN
8       sysctls:
9         net.ipv4.ipforward: 1
10
11     node2:
12       kind: linux
13
14   links:
15     - endpoints: [ "node1:eth1", "bridge:nd1" ]
```

Listing 15: Excerpt of the Containerlab topology definition

5.2.1. Network Topology

The network topology shown in Figure 5.2 illustrates the IP addressing scheme and the interconnections between the individual components.

The `external` node represents an external attacker interacting with the network from the Wide Area Networks (WAN).

The `nsak` container can be deployed in different network segments, enabling the simulation of various attacker positions and reconnaissance scenarios.

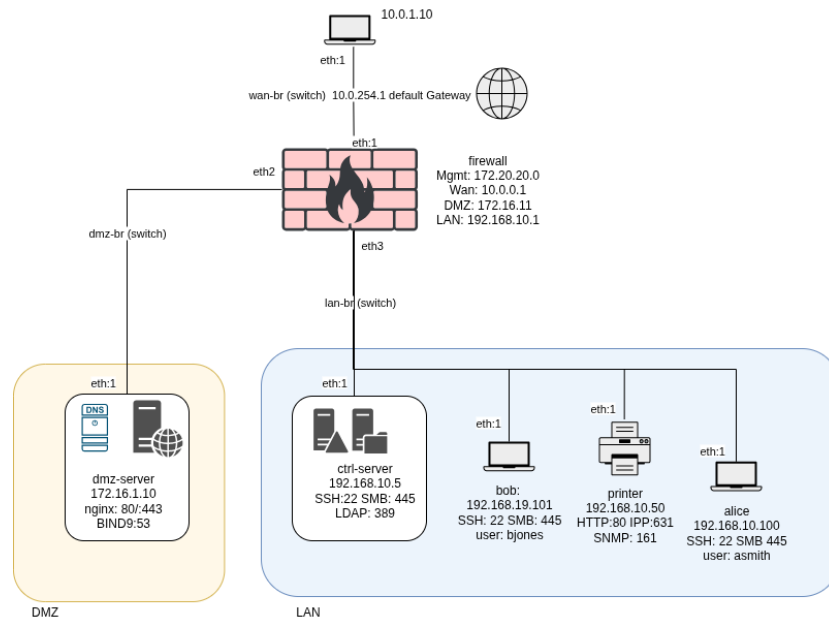


Figure 5.2.: topology-test-environment

5.2.2. DMZ-Server

To evaluate reconnaissance scenarios, common services must run on endpoints.

Berkley Internet Name Domain (BIND) is a complete implementation of the DNS protocol that can be configured through the `named.conf` file as an authoritative name server and resolver.

In the test lab illustrated in 5.2, the functionality of the web server and DNS server was combined for simplicity.

During the De-Militarized Zone (DMZ)-server container build process, a setup shell script is executed.

In the first part, the authoritative BIND `named.conf` file, DNS options, and master zones for forward and reverse lookups are created.

In the forward zone, domain names map to IP addresses, while in the reverse zone, IP addresses map to domain names [22](#).

add
filepath
and
combine
with
other
sections

```

; <<> 016 9.18.44 <<> @172.16.1.10 vlab.local AXFR
; (1 server found)
;; global options: +cmd
vlab.local.      300    IN      SOA     ns1.vlab.local. hostmaster.vlab.local.vlab.local. 2024031501 3600 900 604800 300
vlab.local.      300    IN      NS      ns1.vlab.local.
alice.vlab.local. 300    IN      A       192.168.10.100
bob.vlab.local.  300    IN      A       192.168.10.101
ctrl.vlab.local. 300    IN      A       192.168.10.5
file.vlab.local. 300    IN      A       192.168.10.5
ns1.vlab.local.  300    IN      A       172.16.1.10
printer.vlab.local. 300    IN      A       192.168.10.50
web.vlab.local.  300    IN      A       172.16.1.10
vlab.local.      300    IN      SOA     ns1.vlab.local. hostmaster.vlab.local.vlab.local. 2024031501 3600 900 604800 300
;; Query time: 0 msec
;; SERVER: 172.16.1.10#53(172.16.1.10) (TCP)
;; WHEN: Sat Apr 04 13:34:18 UTC 2026
;; XFR size: 10 records (messages 1, bytes 333)

```

Figure 5.3.: Authoritative Zone Transfer Snippet

The output of a full zone transfer illustrated in figure 5.3 displays the resolved IP addresses and domain names. In our test environment, the restriction of Authoritative Zone Transfer (Full Zone Transfer) requests to only trustworthy IPs is intentionally omitted; the devices are deliberately left unhardened.

In the second part, a minimal Nginx web server with HTTP and HTTPS support is created. Like in real setups, HTTP traffic on port 80 is redirected to HTTPS on port 443. To provide an artifact for reconnaissance purposes, a file named `{secret.txt}` containing sensitive data is placed on the server.

The LAN zone of the network, consists of 4 devices.

5.2.3. Domain Control and File Server

The internal server, reachable at 192.168.10.5, combines the role of domain controller and file server into a single node.

It exposes Secur Shell (SSH) on port 22, Server Message Block (SMB) on ports 139 and 445, and Lightweight Directory Access Protocol (LDAP) on port 389.

The LDAP service is intentionally misconfigured to permit anonymous read access to the entire `dc=lab,dc=local` directory tree, exposing user accounts and group memberships without authentication.

The SMB service provides three shares: `public` is readable without credentials, while `finance` and `it` require valid user accounts.

Sensitive files such as payroll exports and budget summaries are placed in the restricted shares as intentional post-exploitation artifacts 23.

5.2.4. Workstations

Two workstations reside on the LAN segment: Alice at 192.168.10.100, assigned to the Finance department, and Bob at 192.168.10.101, assigned to the IT department.

Both nodes expose SSH on port 22 and SMB on port 445, and both SSH banners intentionally disclose the organization name.

On Alice, the home directory of user `asmith` contains a confidential finance report and a drive mapping file that reveals the path to the central file share on the domain server.

On Bob, the home directory of user `bjones` contains a scripts directory with a host inventory that lists all internal IP addresses and their respective roles [24](#).

5.2.5. Printer

The printer service, reachable at 192.168.10.50, provides two different interfaces. The first web interface is administrative and is available on port 80. It shows internal printer metadata, such as device name and contact information. The printer version is intentionally disclosed in this admin view. The second interface, a REST API, listens on port 631 at the `{/jobs}` endpoint, where it displays a predefined list of print jobs. All printer requests are logged in `{/var/logs/printer_sim_logs}` inside the container [25](#).

5.2.6. Introduced Vulnerabilities

For reconnaissance purposes, several vulnerabilities and flaws were introduced, which are partly mentioned in the previous sections and are presented in detail in Listing [27](#). These flaws are necessary to compare the results of the larger and smaller models as well as the implemented vs the AI-enhanced scenarios.

5.3. AI –Scenarios

5.3.1. AI Agent

LangChain/LangGraph

5.3.2. Human Interaction Hook

-> LangChain: Human-in-the-loop

5.3.3. Local Logging

Python logger

5.3.4. E-Mail Altering

SMTP

5.3.5. CLI Kill Switch

nsak **kill**

5.3.6. Scenario: AI Agent

Initial and agnostic AI-based scenario, which just starts an AI Agent with a custom prompt.

5.3.7. Scenario: AI Reconnaissance

Automatic host discovery based on a specific initial prompt.

5.3.8. Scenario: AI Intrusion Detection

Automatic intrusion detection based on a specific initial prompt.

6. Evaluation

7. Discussion

8. Conclusion

Bibliography

- [1] Polina Zilberman, Rami Puzis, Sanders Bruskin, Shai Shwarz, and Yuval Elovici. Sok: A survey of open-source threat emulators. *arXiv preprint*, 2020.
- [2] Blake E. Strom, Andy Applebaum, Doug Miller, Adam Nickels, Cody Pennington, and Chris Thomas. Mitre att&ck: Design and philosophy. Technical report, MITRE Corporation, 2020.
- [3] Bader Al-Sada, Alireza Sadighian, and Gabriele Oligeri. Mitre att&ck: State of the art and way forward. *ACM Computing Surveys*, 2023.
- [4] MITRE Corporation. Mitre caldera documentation, 2024.
- [5] Red Canary. Atomic red team, 2024.
- [6] Rapid7. Metasploit framework documentation, 2024.
- [7] David Kennedy, Jim O’Gorman, Devon Kearns, and Mati Aharoni. *Metasploit: The Penetration Tester’s Guide*. No Starch Press, 2011.
- [8] Frank Gauss and Lukas von Allmen. Nsak (network swiss army knife). <https://github.com/nsak-team/nsak>, 2026. Accessed: 2026-01-10.
- [9] Wayne Xin Zhao, Kun Zhou, Junyi Li, Tianyi Tang, Xiaolei Wang, Yupeng Hou, Yingqian Min, Beichen Zhang, Junjie Zhang, Zican Dong, et al. A survey of large language models. *arXiv preprint arXiv:2303.18223*, 1(2):1–124, 2023.
- [10] Mohammad Shoeybi, Mostofa Patwary, Raul Puri, Patrick LeGresley, Jared Casper, and Bryan Catanzaro. Megatron-lm: Training multi-billion parameter language models using model parallelism, 2020.
- [11] Anthropic. Model context protocol. <https://www.anthropic.com/news/model-context-protocol>, 2024. Accessed: 2026-03-18.
- [12] Mohammed Mehedi Hasan, Hao Li, Emad Fallahzadeh, Gopi Krishnan Rajbahadur, Bram Adams, and Ahmed E. Hassan. Model context protocol (mcp) at first glance: Studying the security and maintainability of mcp servers, 2025.
- [13] K Huang. Define ai agent. In Ken Huang, editor, *Agentic AI: Theories and Practices*. 2025.

- [14] J Huang K Huang. Define ai agent. In Ken Huang, editor, *Agentic AI: Theories and Practices*. 2025.
- [15] K Jackson C Hughes J Huang, K Huang. Ai agent safety and security considerations. In Ken Huang, editor, *Agentic AI: Theories and Practices*. 2025.
- [16] Risky Business Feature Podcast. ...mcp is dead. <https://risky.biz/>, 2026. Podcast episode , Accessed: 2026-03-18.
- [17] Ethan Michalak and Mark Perry. Connecting llms to caldera with the mcp plugin. <https://medium.com/@mitrecaldera/connecting-llms-to-caldera-with-the-mcp-plugin-da1450254827>, 2025. MITRE Caldera Blog, Accessed: 2026-03-16.
- [18] GH05TCREW. Metasploit mcp server. <https://github.com/GH05TCREW/MetasploitMCP>, 2025. Accessed: 2026-03-16.
- [19] Hare Sudhan. Atomic red team mcp server. <https://github.com/cyberbuff/atomic-red-team-mcp>, 2025. Accessed: 2026-03-16.
- [20] Containerlab Authors. Containerlab documentation, 2026. Accessed: 2026-04-03.
- [21] Advisera. Iso 27001 risk assessment, treatment, and management: The complete guide, 2025. Accessed: 2026-03-04.
- [22] Simplr. General recommended vram guidelines for llms, 2025. Online; accessed 10 March 2026.

List of Figures

5.1. EnvironmentLoader Base Class Refactoring Diff	33
5.2. topology-test-environment	39
5.3. Authoritative Zone Transfer Snippet	40
A.1. Checklist and Burndown Sprint1	60
A.2. Sprint Retro 1	61
A.3. Roadmap Sprint Planning 2	63
A.4. Milestone Description and Charts: Compare Frameworks	64
A.5. Milestone Description and Charts: Configuration Management	65
A.6. Sprint Retro 2	66
A.7. Roadmap Sprint Planning 3	68
A.8. Risks Brainstorming	77
A.9. Risks Brainstorming	78
A.10. Risk Assessment	79
A.11. Variant 1: AI vs Manually Built Scenarios	85
A.12. Variant 2: Multiple Blue and Red Team Scenarios	86
A.13. AI Integration Variant 1: AI-agent in NSAK	87
A.14. Variant 1, AI Agent in NSAK	87
A.15. AI Integration Variant 2: NSAK as MCP server	88
A.16. Variant 2 NSAK MCP Server	88
A.17. Brainstorm Scenarios	90
A.18. Clustering possible Scenarios	91
A.19. NSAK Scenario: Network Discovery - Red Team	93
A.20. NSAK Scenario: TLS Downgrade Poodle - Red Team	94
A.21. NSAK Scenario: TLS Downgrade Poodle -Topology	95
A.22. NSAK Scenario: Honeypot - Blue Team	96
A.23. NSAK Scenario: Traffic Capture - Red Team	97
A.24. NSAK Scenario: Intrusion Detection - Blue Team	98
A.25. FRITZ!Box DynDNS Setup	104
A.26. Infomaniak DynDNS Setup	104
A.27. FRITZ!Box DynDNS Setup	105
A.28. FRITZ!Box DynDNS Setup	106

List of Tables

2.1. Comparison of Metasploit, Atomic Red Team, and MITRE Caldera ([1, 4–6])	10
5.1. Device Resource Classes	27
5.2. Resource Python Classes	27
A.1. Key Scrum Meetings	52
A.2. Issue Board	53
A.3. Definition of Ready Criteria for Tickets	53
A.4. Definition of Done Criteria for Tickets	54
A.5. Project Milestone Overview in GitLab	55
A.6. Sprint Planning 2	62
A.7. Sprint Planning 3	67
A.8. Risk categories used for the project risk assessment	75
A.9. Risk evaluation criteria	75
A.10. Risk probability scale	76
A.11. Risk impact scale	76
A.12. Risk level classification (probability and impact are interchangeable)	76
A.13. Risk Treatment Strategies	78
A.14. Meeting Notes: Checkpoint 1	80
A.15. Meeting Notes: Checkpoint 2	81
A.16. Meeting Notes: Checkpoint 3	82
A.17. Meeting Notes: Checkpoint 4	83
A.18. Hardware configuration of the self-hosted LLM inference server.	99

List of Listings

1.	NSAK Static Configuration	22
2.	NSAK Runtime Configuration	24
3.	NSAK CLI Initialisation	25
4.	Persisted Runtime Configuration (run/config.yaml)	26
5.	Device Resource YAML Specification	27
6.	NSAK CLI: List Devices	28
7.	Device Resource Configuration YAML Specification	28
8.	DeviceLoader Configuration Parsing	30
9.	Device Configuration Datastructures	31
10.	Device Configuration CLI Management	32
11.	Mergeable Resource YAML Specification	34
12.	Updated Interface Specification	34
13.	discover_hosts Drill YAML	35
14.	mitm Scenario YAML	36
15.	Excerpt of the Containerlab topology definition	38
16.	Local LLM System Setup	100
17.	/home/ai/docker-compose.yml	101
18.	swag/nginx/site-confs/default.conf	102
19.	UFW configuration	103
20.	Restart SWAG Container	105
21.	Firewall	107
22.	Web-Server and DNS	108
23.	File Server and Domain Control	109
24.	Work-Stations Bob and Alice	110
25.	Printer	111
26.	Links	111
27.	Introduced Vulnerabilities in the Virtual Enterprise Network	113

Glossary

This document is incomplete. The external file associated with the glossary ‘main’ (which should be called `thesis.gls`) hasn’t been created.

Check the contents of the file `thesis.gls`. If it’s empty, that means you haven’t indexed any of your entries in this glossary (using commands like `\gls` or `\glsadd`) so this list can’t be generated. If the file isn’t empty, the document build process hasn’t been completed.

If you don’t want this glossary, add `nomain` to your package option list when you load `glossaries-extra.sty`. For example:

```
\usepackage[nomain]{glossaries-extra}
```

Try one of the following:

- ▶ Add `automake` to your package option list when you load `glossaries-extra.sty`. For example:

```
\usepackage[automake]{glossaries-extra}
```

- ▶ Run the external (Lua) application:

```
makeglossaries-lite.lua "thesis"
```

- ▶ Run the external (Perl) application:

```
makeglossaries "thesis"
```

Then rerun $\text{\LaTeX}$ on this document.

This message will be removed once the problem has been fixed.

A. Project Management

A.1. Stakeholders

Hj. Wenger: Instructor and Network Specialist

Urs Keller: Expert and Entrepreneur

A.2. Agile Management Process

The project followed an interactive development approach using Gitlab for issue tracking and planning. We defined our project management in a Scrum-like manner, but we individualized the process according to the projects scope and our needs. Work items were organized into epics, milestones and issues. Each iteration lasts two weeks. We decided to hold the following Scrum ceremonies after each sprint:

Sprint Planning	Sprint Review	Sprint Retro	Checkpoint
Select milestone with sprint goal	Close open tickets	Reflect on sprint	Present sprint results
Check issues for DoR and obstacles	Gather team feedback	Identify improvements	Get stakeholder feedback
Ensure issues are clear	Validate delivered features	Discuss what went well	Define next tasks
Create sprint backlog	Review progress	Discuss issues/problems	Discuss issues/problems

Table A.1.: Key Scrum Meetings

The workflow used for ticket tracking consisted of the following stages:

A.2.1. Issue Lifecycle:

Buckets	Description
Backlog	List of all tasks and features planned for the project.
Todo	Tasks selected for the current sprint that are ready to be worked on.
Q&A	Tasks waiting for clarification, review, or testing.
Done	Completed tasks that meet the defined acceptance criteria.

Table A.2.: Issue Board

A.2.2. Definition of Ready (DoR)

Category	Criteria
Clarity	▶ Clear and precise title ▶ Objective or problem described in two to three sentences ▶ Scope clearly defined
Scope	▶ Affected module specified (drill, scenario, core, container, frontend) ▶ External dependencies identified
Validation	▶ Testable acceptance criteria defined ▶ Expected behavior clearly specified

Table A.3.: Definition of Ready Criteria for Tickets

A.2.3. Definition of Done (DoD)

Category	Criteria
Implementation	▶ All acceptance criteria fulfilled ▶ Container execution verified ▶ Pre-commit hooks pass ▶ Logging and error handling consistent
Testing	▶ Feature or bug fix tested ▶ Acceptance criteria verifiable (automated or manual) ▶ Relevant edge cases considered ▶ Execution reproducible
Documentation	▶ README updated if required ▶ Architecture changes documented ▶ Thesis relevance briefly noted ▶ Limitations documented ▶ Required documentation stored for thesis or appendix

Table A.4.: Definition of Done Criteria for Tickets

A.3. Project Structure

This section describes the projects structure and list the goals as milestones linked to their respective page in GitLab.

A.3.1. Milestones

A milestone represent crucial steps toward the overall project goal. Per our definition a milestone has at least one epic and the mandatory milestones are listed in [Table A.5](#)

GitLab Milestones

[Project Management](#)
[Research AI Integration](#)
[Research: Compare Frameworks](#)
[NSAK Framework: Configuration Management](#)
[NSAK Scenario: Network Discovery - Red Team](#)
[NSAK Scenario: AI Scenarios](#)
[Reproducible Test Environment](#)

Table A.5.: Project Milestone Overview in GitLab

[Project Planning](#)

19.02.2026 – 10.03.2026

This is the initial milestone which is used to plan the whole project and bachelor thesis.

- ✓ The bachelor thesis is planned as an agile (scrum-like) project
- ✓ A risk analysis for the project was conducted and the identified risks are assessed and addressed
- ✓ All meetings, deadlines, scrum ceremonies and sprints are added to the Outlook calendar
- ✓ The goals of the thesis are defined and categorized as “must”, “should” and “could”
- ✓ The goals are created as milestones and divided into epics, categorized by the labels: Project Management, Research, Framework, Implementations, Documentation
- ✓ We know how we coordinate the project with the stakeholders (instructor and expert)

[Research: AI Integration](#)

10.03.2026 – 22.03.2026

The goal of this research milestone was to investigate how AI can support automated security testing and adversary emulation. The research evaluated potential integration points where AI could enhance scenario execution, automation, decision-making, and analysis capabilities of the NSAK framework. The milestone was extended by three days following input from the expert and instructor to clarify the intended interaction between LLMs and NSAK.

- ☐ How is AI currently used in cybersecurity automation?
- ☐ Which tasks in adversary emulation can be supported or automated by AI?
- ☐ How could AI interact with the NSAK scenarios and drills (e.g. Agents, MCP)?
- ☐ What architectural changes would be required to integrate AI into NSAK?

Research: Compare Frameworks

10.03.2026 – 19.03.2026

This milestone focused on the research and comparison of existing security automation frameworks that could potentially support or influence the NSAK scenario and drill execution model. The evaluation included frameworks such as MITRE CALDERA and Atomic Red Team, examining their execution models, configuration and parameter handling, extensibility mechanisms, and the structure of reusable test definitions.

The expected outcomes were:

- ☐ A short comparison of selected frameworks
- ☐ A summary of relevant architectural concepts
- ☐ An initial assessment of how these frameworks relate to NSAK

NSAK Framework: Configuration Management

10.03.2026 – 19.03.2026

This milestone defined the configuration model and execution framework for NSAK scenarios. It introduced a structured approach for configuring scenarios and drills, including typed argument declarations, and the generation of a resolved run configuration. The goal was to provide a flexible and reproducible configuration system that allows scenarios and drills to expose parameters and execute in a defined order.

- ✓ Drills and scenarios can expose runtime parameters as configuration objects
- ✓ The configuration objects can be set via CLI arguments
- ✓ A configuration management system is implemented in the NSAK framework

NSAK Scenario: Network Discovery – Red Team

02.04.2026 – 16.04.2026

Network discovery is one of the most essential Red Team activities in the reconnaissance phase. This milestone covered the implementation of a scenario that identifies network participants and services, producing a structured network map that can be consumed by subsequent drills such as Address Resolution Protocol spoofing.

Goals (Must):

- ☐ The scenario identifies the available ports and interfaces on the device
- ☐ The scenario discovers the available subnets and obtains valid addresses
- ☐ The scenario discovers addresses, addresses and services (port scan)
- ☐ The scenario supports at least a fast full-search mode
- ☐ The scenario returns a network map as a structured data type

Goals (Could):

- ☐ A human interaction hook allows the operator to select the discovery mode
- ☐ Additional modes: slow full search, distinct search

[NSAK Scenario: AI Scenarios](#)

19.03.2026 – 16.04.2026

This milestone explored what happens when an AI agent is given full access to the NSAK framework for both Red and Blue Team activities. The scenario is intentionally open-ended, reflecting the research nature of the milestone.

Goals (Must):

- ☐ The operator can provide a custom prompt or select a predefined Red or Blue Team prompt
- ☐ The scenario runs an AI agent with a remote connection
- ☐ An operator can interact with the agent via CLI at all times
- ☐ The scenario logs all relevant actions and network traffic locally
- ☐ The AI can trigger an e-mail alert to notify an operator
- ☐ The scenario has a kill switch to stop execution at any time

Goals (Should):

- ☐ Human interaction hook via Web GUI
- ☐ Remote logging and sniffing
- ☐ Kill switch with full device shutoff

Reproducible Test Environment

19.03.2026 – 02.04.2026

The goal of this milestone was to design and implement a reproducible and safe test environment for the NSAK framework, providing a stable basis for consistent execution and evaluation of both manual and AI-assisted scenarios.

- ☐ The test environment can be set up reproducibly using Infrastructure as Code (e.g. Ansible)
- ☐ NSAK scenarios and drills can be executed consistently within the environment
- ☐ The environment supports both manual and AI-assisted scenarios
- ☐ Scenario results can be collected and analyzed for evaluation purposes

A.3.2. Epics

consist of multiple stories and contribute to fulfilling milestones.

A.3.3. Issues

Each Story is assigned a weight, sprint, milestone and epic and are usually represented by an “Issue” in gitlab.

A.4. Sprints / Iterations

A.4.1. Planning

“Task” and “Issue”, the terms are often used interchangeably with “Stories”. Stories must meet the [A.2.2](#) before implementation and [A.2.3](#) before closing.

A.5. Planning and Estimation

The following estimation strategy was used:

- ▶ 1 hour corresponds roughly to 1 weight point
- ▶ Iteration length: 2 weeks
- ▶ Weights per iteration: 40h per person = 80 weight per iteration
- ▶ Sprint planning duration: 1.5 hours per iteration
- ▶ Sprint review duration: 1 h per iteration

- ▶ Sprint retro duration: 1 h per iteration

A.6. Project Roadmap

To keep track of the overall progress in the project, the project team uses the “Roadmap” feature in GitLab. After each sprint planning meeting we create a new screenshot of the roadmap and add it to the according sprint section in [A.7](#). The first sprint planning is an exception, because at this point the diagram would have been empty.

A.7. Sprint Ceremonies

A.7.1. Sprint 1: 19.02 –10.03.2026

Sprint Planning 1: 19.02.2026

For the planning of sprint 1 we derived all issues from the milestone project management [A.5](#) and had an overall weight from 89.

Sprint Review 1: 10.03.2026

The milestone was successfully reached, and the board was cleared in preparation for the next sprint. All issues were reviewed and moved to the “Done” column.

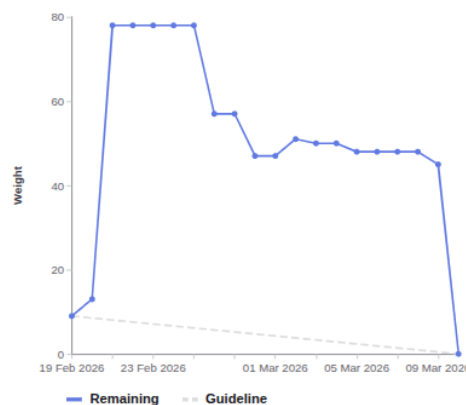
Milestone Review: Project Management As shown in burndown and burnup charts [A.1](#) of the Project Planning [A.3.1](#) milestone, all deliverables were fulfilled. However, the deadlines of the milestone had to be moved to the 10.03.2026, because the project planning required more time than initially expected. It should also be noted that the charts abruptly go down or up respectively, as we closed alot of the tickets after we reviewed them together just before we held this meeting.

Project Planning

- ☒ The bachelor thesis is planned as an agile (scrum like) project
- ☒ A risk analysis for the project was conducted
- ☒ The identified risks are assessed and addressed
- ☒ All meetings, deadlines, scrum ceremonies and sprints are added to the outlook calendar
- ☒ The goals of the thesis are defined and categorized as "must", "should" and "can"
- ☒ The goals are created as milestones and divided into epics, which are categorized by the labels: "Project Management", "Research", "Framework", "Implementations", "Documentation"
- ☒ We know how we coordinate the project with the stake holders (instructor and expert)

Display by Count Weight

Burndown chart



Burnup chart

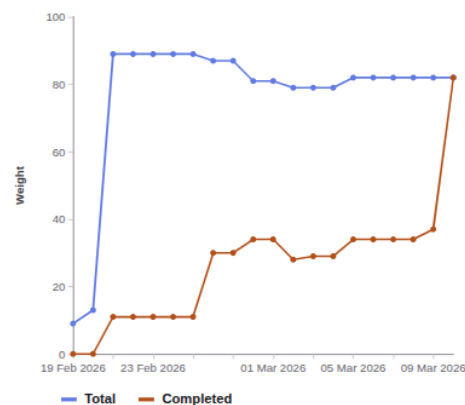


Figure A.1.: Checklist and Burndown Sprint1

Sprint Retro 1: 10.03.2026

This sprint retro was held in Microsoft Whiteboard as it provides simple templates, the result is illustrated in A.2.

Key Takeaways:

- Maintain clear and consistent communication with the instructor.
- Be aware of maintaining a healthy work–life balance during the project.
- Apply lean project management practices to keep the process efficient and focused.

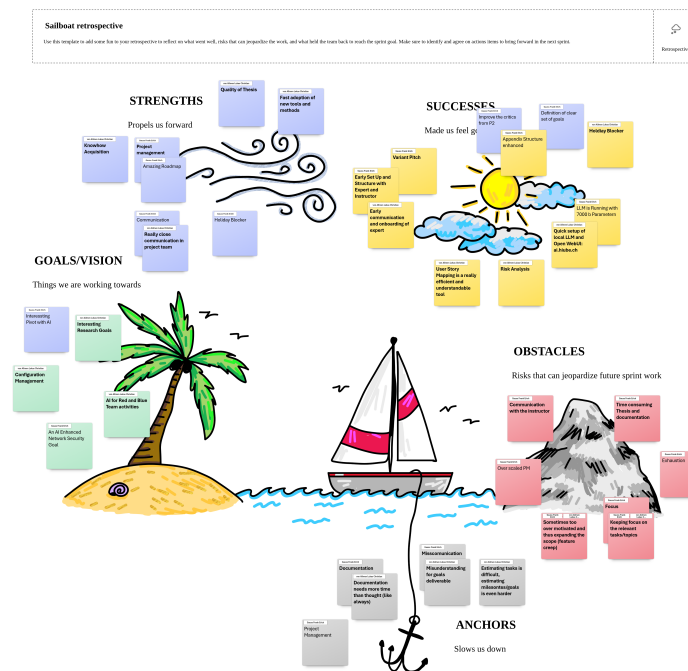


Figure A.2.: Sprint Retro 1

A.7.2. Sprint 2: 05.03 –18.03.2026

Sprint Planning 2: 05.03.2026

The current state of the project roadmap is shown in the following screenshot [A.3](#).

Week	Responsible	Task
Week 1	Lukas	Configuration management implementation
Week 1	Frank	Research and comparison of frameworks
Week 1	Team	AI workshop on Thursday and writing of the related issues
Week 2	Team	AI research and evaluation
Week 2	Team	Preparation and pitch of the project deliverables

Table A.6.: Sprint Planning 2

A. Project Management

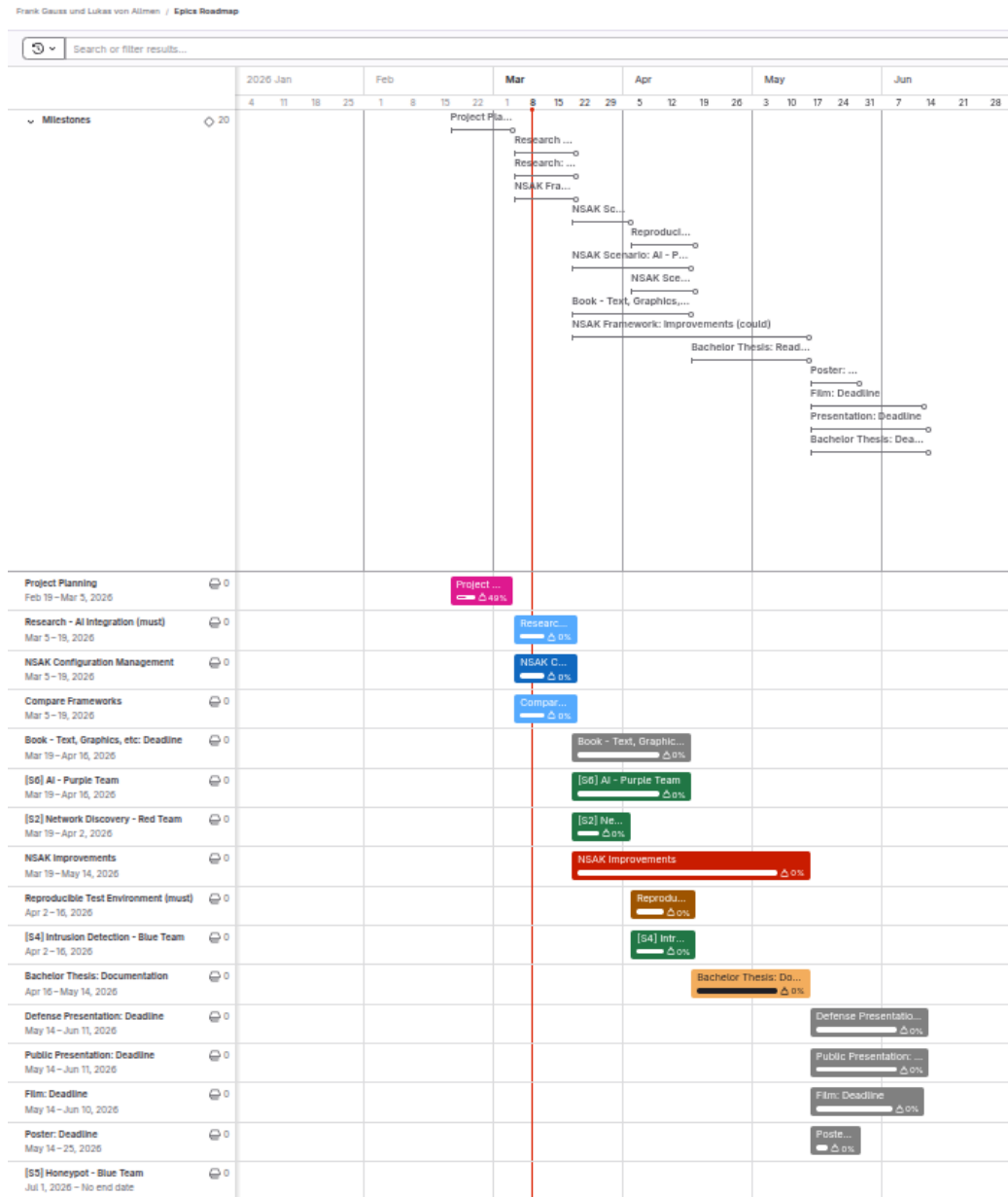


Figure A.3.: Roadmap Sprint Planning 2

Sprint Review 2: 19.03.2026

We got some helpful inputs related to both milestones from the tutor and expert in the checkpoint meeting [A.8.3](#) earlier this day. We decided to still consider the milestone to be successfully reached as the planned work package and deliverables were finalized and presented. The resulting follow-up tasks are planned for

the next week and as a consequence we will hold the next sprint planning [A.7.3](#) a week later than planned. All issues were reviewed and moved to the “Done” column in preparation for the next sprint. It must be noted that the burnup and burndown charts are not really representative, as the project team often reviews and closes the tickets at the end of the sprint.

Milestone Review: Compare Frameworks The Compare Frameworks [A.3.1](#) milestone is completed as illustrated in [A.4](#).

Research: Compare Frameworks (must)

Description

This milestone focuses on the research and comparison of existing security automation frameworks that could potentially support or influence the NSAK scenario and drill execution model.

The objective of this research is to understand how established frameworks structure and execute security tests, manage configuration, and organize reusable components.

The evaluation will include frameworks such as MITRE CALDERA and Atomic Red Team, which represent different approaches to security automation.

List of pre-work/papers:

The comparison will focus on key aspects relevant for NSAK, including:

- execution models (scenarios, abilities, tests)
- configuration and parameter handling
- extensibility and plugin mechanisms
- structure and reuse of test definitions

The results of this research will provide the foundation for a framework gap analysis, where the capabilities of the evaluated frameworks are compared against the NSAK requirements.

The outcome of this milestone will be:

- a short comparison of selected frameworks
- a summary of relevant architectural concepts
- an initial assessment of how these frameworks relate to NSAK

The findings will serve as input for the subsequent gap analysis milestone.

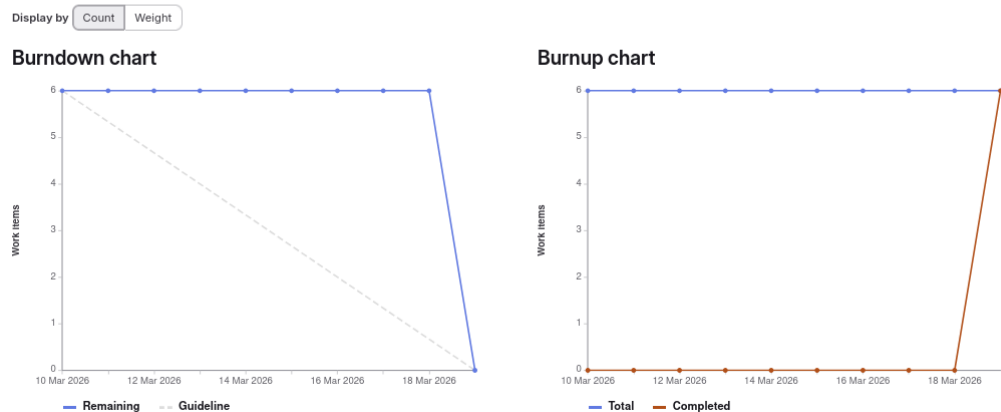


Figure A.4.: Milestone Description and Charts: Compare Frameworks

Milestone Review: Configuration Management The burnup and burndown charts below [A.5](#) are showing that the milestone Configuration Management [A.3.1](#) is implemented as planned.

NSAK Framework: Configuration Management (must)

☐ A configuration management is implemented into the NSAK Framework

Setup

Current configuration approach: ENV vars, CLI flags or hardcoded New configuration approach:

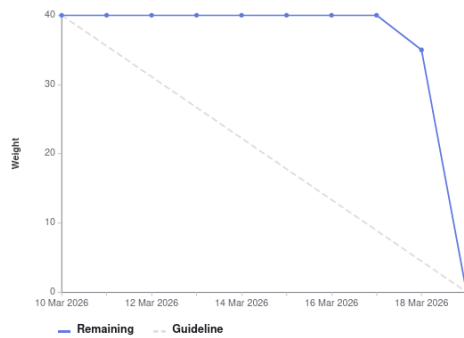
- Drills and scenarios can expose build and runtime parameters as a configuration objects
- The configuration objects can be set interactively during `nsak scenario build` or `nsak scenario run`
- Alternatively the configuration objects can be set as CLI parameters (e.g. JSON)
- Alternatively the configuration objects can be provided via file (e.g. JSON)

This milestone defines the configuration model and execution framework for NSAK scenarios. It introduces a structured approach for configuring scenarios and drills, including drill definitions, reusable presets, and the generation of a resolved run configuration.

The goal is to provide a flexible and reproducible configuration system that allows scenarios to expose parameters, merge configuration layers, and execute drills in a defined order.

Display by Count Weight

Burndown chart



Burnup chart

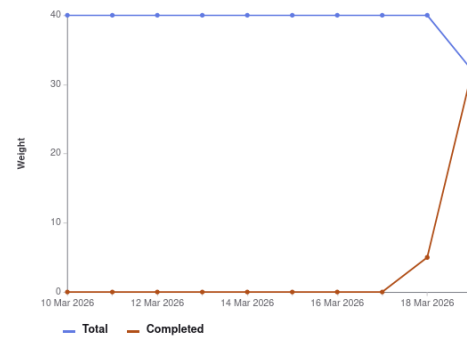


Figure A.5.: Milestone Description and Charts: Configuration Management

Sprint Retro 2: 19.03.2026

This sprint retro was held in Microsoft Whiteboard as it provides simple templates, the result is illustrated in [A.6](#).

Key Takeaways:

- ▶ The long project planning phase greatly helped us with the projects overview and minimizes the planning needed for each sprint.
- ▶ The “focus weeks” really boosted the projects progress, and we are looking forward to the next “focus weeks”.
- ▶ Because we did not review tasks (Quality Assurance (QA)) on a regular basis, all this work needed to be done at the end of an iteration.
- ▶ Reviewing on a more regular basis would also lead to more accurate burn-down and burnup charts.

4L's retrospective

Use this template to conduct a retrospective on your team's last sprint. Fill out each of the quadrants while considering the following questions: What did your team like? What did your team lack? What did the team learn? What does the team wish for?



Strategy

LIKED	LEARNED
Focus Project Time Workshop and communication Focus on key deliverables pragmatic Constructively meeting with expert and instructor with shared thesis Agenda und Result Two weeks of focus helped to boost progress and really get into the topics Output of the Research Milestones (AI and Framework Comparison) Planning helped splitting tasks and responsibilities efficiently Review takes time too	Review fluently to improve charts and processes and improve backward tracability Show only graphics with clear intension maybe prepare links in the chapter to jump to the right section for sharring inside the thesis Plan less tasks in a sprint, its always more work than we think Review takes time too Make diagrams more simple (stakeholders may not have the same context)
LACKED	LONGED FOR
Life around the project needed more time as expected constantly of reviewing the assigned tasks actual view of roadmap needs to be displayed in pm part of thesis Time for documentation Syncing understanding of the AI tech stack with stakeholders	More proficience with scientific writing citation help Faster implementation of concepts, code and documentation

Figure A.6.: Sprint Retro 2

A.7.3. Sprint 3: 19.03 –01.04.2026

Sprint Planning 3: 26.03.2026

Because we got some important input regarding variant decision for AI-integration, framework comparison, and configuration management [A.16](#) which led to additional work. As consequence of this, we decided to shorten the third sprint to one week, which is reflected in the following table [A.7](#) and postponed the sprint planning from the 19.03 to the 26.03. To account for the delayed start in the overall planning we adjusted it as shown in the [A.7](#).

Week	Responsible	Task
Week 1	Frank	Reproducible Test Environment implementation
Week 1	Lukas	NSAK Scenario: AI Scenarios (first part)

Table A.7.: Sprint Planning 3

Sprint Review 3: 02.04.2026

Sprint Retro 3: 02.04.2026

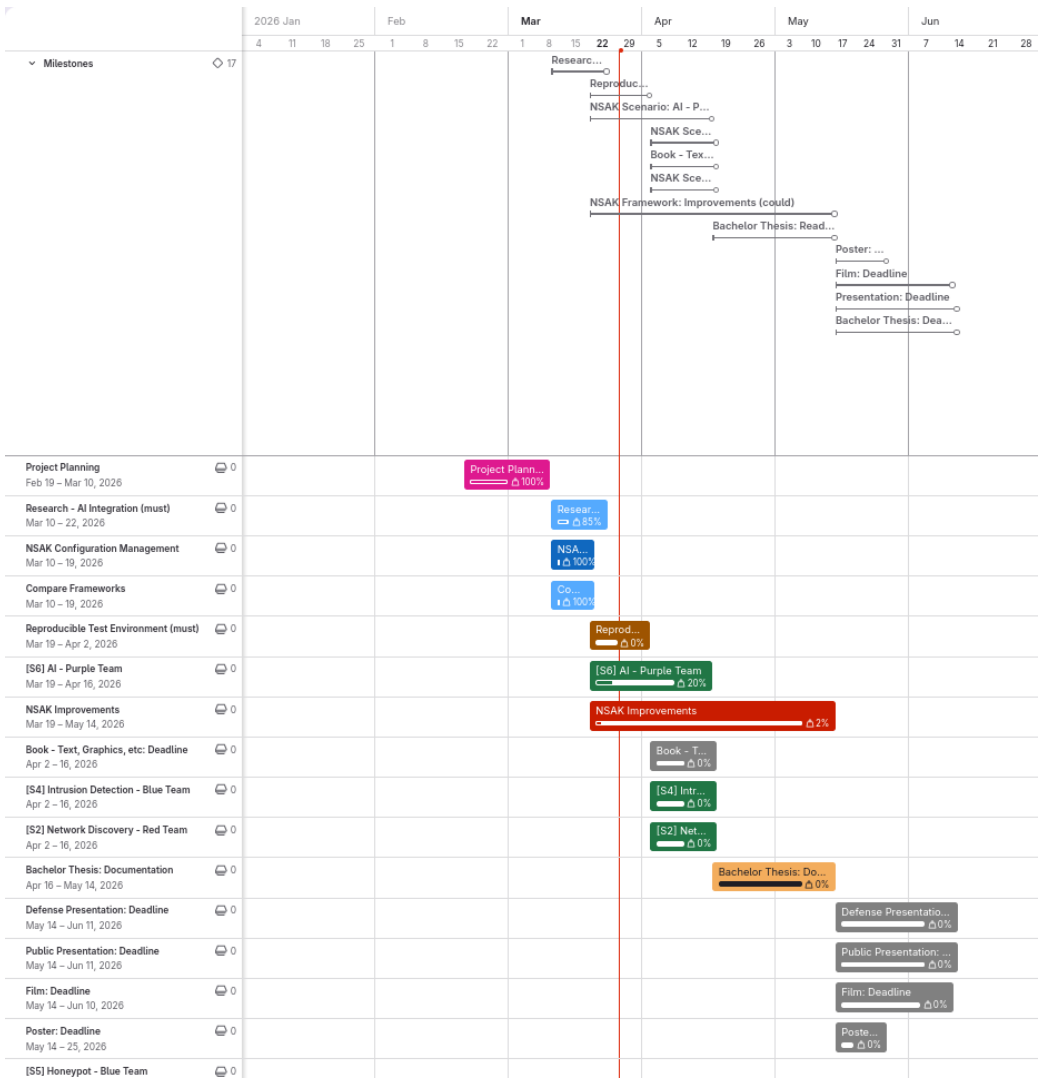


Figure A.7.: Roadmap Sprint Planning 3

A.7.4. Sprint 4: 02.04 –15.04.2026

Sprint Planning 4: 02.04.2026

Sprint Review 4: 16.04.2026

Sprint Retro 4: 16.04.2026

A.7.5. Sprint 5: 16.04 –29.04.2026

Sprint Planning 5: 16.04.2026

Sprint Review 5: 30.04.2026

Sprint Retro 5: 30.04.2026

A.7.6. Sprint 6: 30.04 –13.05.2026

Sprint Planning 6: 30.04.2026

Sprint Review 6: 13.05.2026

Sprint Retro 6: 13.05.2026

A.7.7. Sprint 7: 14.05 –27.05.2026

Sprint Planning 7: 14.05.2026

Sprint Review 7: 28.05.2026

Sprint Retro 7: 28.05.2026

A.7.8. Sprint 8: 28.05 –10.06.2026

Sprint Planning 8: 28.05.2026

Sprint Review 8: 11.06.2026

Sprint Retro 8: 11.06.2026

Rewrite
in past
tense

A.7.9. Risk Assessment

To methodically conduct the risk assessment the section “Risk assessment” from an online guide published by Advisera [21], which describes the risk assessment process according to ISO 27001, was used as a reference.

Risk Assessment Process:

1. Risk categories and criteria: Define which dimensions and taxonomies are important for the assessment.
2. Risk identification: Collect possible risks in a brainstorming session.
3. Risk analysis: Assess the risks criteria on a risk matrix.
4. Risk evaluation: Create a list of risks ordered by the resulting risk level and evaluate if they are acceptable or need treatment.
5. Risk treatment: Describe the strategy and how to treat the risks.

Risk Categories & Criteria:

The table A.8 shows four commonly used categories, which were used to group the risks.

Category	Description
Strategic Risk	Risks related to business decisions (e.g., wrong prioritization).
Operational Risk	Risks related to internal processes (e.g., Scrum, QA process).
Financial Risk	Risks related to costs and expenses (e.g., hardware costs).
External Risk	Risks related to uncontrollable sources (e.g., force majeure).

Table A.8.: Risk categories used for the project risk assessment

The criteria for analysing the risks are summarized in the table A.9

Criterion	Description
Probability	Likelihood that the risk will occur.
Impact	Severity of consequences if the risk materializes.
Level	Risk level calculated as Probability + Impact.

Table A.9.: Risk evaluation criteria

The levels of the criteria and their respective numerical weights are listed in the tables A.10 and A.11.

Level	Weight	Description
Low	1	Unlikely
Medium	2	Possible
High	3	Likely

Table A.10.: Risk probability scale

Level	Weight	Description
Low	1	Minor inconveniences
Medium	2	Delays milestones or reduces scope
High	3	Threat to the thesis

Table A.11.: Risk impact scale

The following table [A.12](#) defines the calculation method and the resulting risk levels, used for the assessment.

Risk Level	Weight	Calculation
Very Low	2	Low + Low
Low	3	Low + Medium
Medium	4	Medium + Medium / Low + High
High	5	Medium + High
Critical	6	High + High

Table A.12.: Risk level classification (probability and impact are interchangeable)

Risk Identification

The identification process was conducted with the help of a digital brainstorming, where the risks are already grouped by category. The identified risks are represented by the cards shown in [A.8](#). The respective risk categories are visualized by the color coding of the cards and described in the legend.

Risk Brainstorming

- Strategic Risk:** Risks related to business decisions (e.g. wrong prioritization).
- Operational Risk:** Risks related to internal processes/procedures (e.g. Scrum, QA process).
- Financial Risk:** Risks related to costs and expenses (e.g. hardware costs).
- External Risk:** Risks related to uncontrollable sources (e.g. Force majeure).

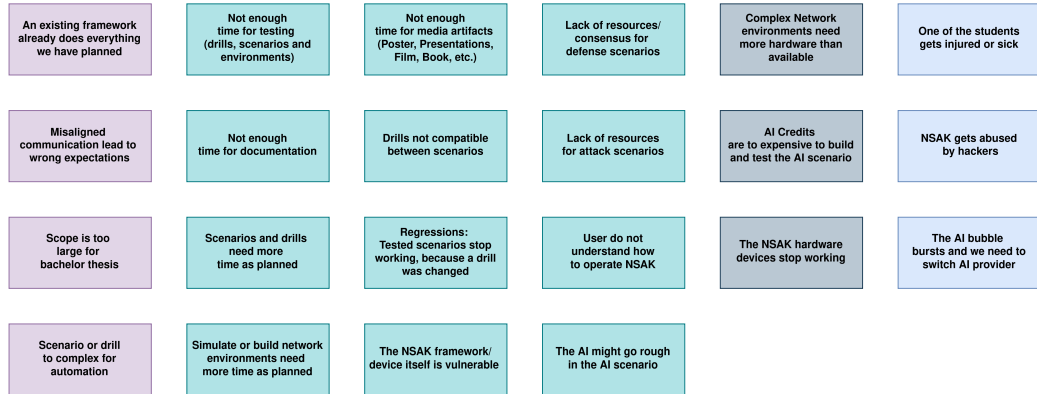


Figure A.8.: Risks Brainstorming

Risk Analysis

For analysing the risks a matrix was prepared, where the criteria “Impact” and “Probability” are representing the x- and y-axis respectively. The project team then assessed the criteria for each individual risk and placed them on the matrix accordingly. In a second step, the risks were moved if they did not fit relatively to each other. The resulting “Risk Analysis Matrix” is illustrated in the following figure A.9. The background color of the cells is representing the resulting risk level of the tasks.

Risk Matrix

Probability	High	The NSAK framework/device itself is vulnerable User do not understand how to operate NSAK Regressions: Tested scenarios stop working, because a drill was changed Not enough time for testing (drills, scenarios and environments) Simulate or build network environments need more time as planned AI Credits are to expensive to build and test the AI scenario
	Medium	An existing framework already does everything we have planned The AI might go rough in the AI scenario Complex Network environments need more hardware than available Scenarios and drills need more time as planned Not enough time for documentation Scope is too large for bachelor thesis Drills not compatible between scenarios Misaligned communication lead to wrong expectations The AI bubble bursts and we need to switch AI provider Not enough time for media artifacts (Poster, Presentations, Film, Book, etc.) Scenario or drill to complex for automation
	Low	Lack of resources for attack scenarios Lack of resources/consensus for defense scenarios The NSAK hardware devices stop working NSAK gets abused by hackers One of the students gets injured or sick
		Low Medium High
		Impact

Figure A.9.: Risks Brainstorming

Risk Evaluation & Treatment

In a first step a table with the required columns was created. Then the risks and weights for the criteria were added with an ID in the format “R-000”, to easier reference them in the thesis later on. After sorting the table by the calculated risk level, the risk evaluation was conducted by deciding which treatment strategy described in A.13 we want to apply.

Strategy	Description
Mitigate	Reduce the likelihood or impact of a risk.
Transfer	Move the risk to a third party.
Accept	Acknowledge the risk and take no further action.
Avoid	Eliminate or circumvent the cause of the risk.

Table A.13.: Risk Treatment Strategies

Finally, the project team went through the risks and discussed how to treat them effectively. The resulting “Risk Assessment” is illustrated in the following table A.10.

Figure A.10.: Risk Assessment

Risk Assessment		Criteria			Category		
		2 - Medium		2 - Low		Critical	
		3 - High		4 - Medium			
		5 - Critical		6 - Critical			
Risk ID	Description	Risk Category	Probability	Impact	Level	Strategy	Treatment
R401	AI control as too expensive to build and test the AI scenario	Financial	3	3	9	Avoid	Use a self-hosted LLM, check if the BPT can provide AI services or if there are two pairs for education
R406	Scops is too large or butcher thesis	Strategic	2	3	6	Mitigate	We have to plan and evaluate the goals carefully. The use of "User Story Maps" also helps to mitigate the risk.
R407	Scenario or drill too complex for automation	Strategic	2	3	6	Mitigate	Create "User Story Maps" for experts, so that we have a good understanding of the scenarios and their drills.
R402	No enough time for documentation	Operational	2	3	6	Mitigate	Add a dedicated documentation issue with an according weight to each epic.
R403	No enough time for testing (drills, scenarios and environments)	Operational	2	3	6	Mitigate	Add a dedicated testing issue with an according weight to each epic.
R404	Simulating or building network environments takes more time than planned	Operational	3	2	6	Mitigate	Add dedicated issues with according weight to each scenario epic.
R405	User does not understand how to operate NSMx	Operational	3	2	6	Mitigate	Provide a Web GUI and/or user guides
R412	Misaligned communication leads to wrong expectations	Strategic	2	2	4	Mitigate	Multiple channels and Bi-Weekly Meetings should keep the communication aligned.
R410	Scenarios and drills made more time than planned	Operational	2	2	4	Mitigate	Use "User Story Maps" to get a good idea of the required steps to build the scenario. It's a drifts and estimate generously.
R411	No enough time for media articles (poster, presentations, film book, etc.)	Operational	2	2	4	Mitigate	Include the creation of the media articles as milestones in the project planning
R409	Complex network environments need more hardware than available	Financial	2	2	4	Avoid	We can simulate network environments instead of real hardware.
R408	The Alibaba burst and we need to switch AI provider	External	2	2	4	Avoid	Use vendor agnostic tools and protocols, so that we can switch provider easily.
R415	Regression tested scenarios stop working because a drift was changed	Operational	3	1	3	Mitigate	Add automated test cases by debating regressions early.
R415	The NSMx framework/device itself is vulnerable	Operational	3	1	3	Transfer	Clearly state that the NSMx framework/device is still a POC and not ready for production use.
R413	One of the students got injured or sick	External	1	3	3	Accept	We accept this risk.
R419	An existing framework already does everything we have planned	Strategic	2	1	2	Accept	We accept the risk, but will compare well known frameworks with NSMx and highlight our USP (HW and AI).
R417	Drills not compatible between scenarios	Operational	2	1	2	Mitigate	The implementation of the configuration management should provide a way that small deviations can be prevented.
R418	The AI might go rogue in the AI scenario	Operational	2	1	2	Mitigate	Besides the fact that we have physical access to the device we add a safeguard to the AI scenario.
R416	The NSMx hardware device stops working	Financial	1	2	2	Accept	The fact that we have two devices already reduces the impact. Further we could also use other HW.
R421	Lack of resources for attacks scenarios	Operational	1	1	1	Mitigate	Get familiar and use the MITRE ATT&CK framework as reference and source.
R422	Lack of resources / consensus for adverse scenarios	Operational	1	1	1	Mitigate	Get familiar and use well known sources such as NIST as source.
R420	NSMx gates blocked by blockers	External	1	1	1	Transfer	Clearly state that the NSMx framework/device is built only for educational and white hat purposes.

A.8. Meeting Notes

A.8.1. Checkpoint Meeting 1: 26.02.26

Participants	Hj. Wenger (Instructor), Frank Gauss, Lukas von Allmen
Agenda	- Goals presentation via slides - Clarification whether there is a deadline or submission required for the presentation (besides adding it to the addendum). - Clarification whether the defense presentation should be an enhanced version of the public presentation or a separate, more technical presentation. - Proposal to establish a recurring meeting series every Thursday at 15:00 during the semester.
Tasks	- Hand in a set of success criteria for the project goals: We thought we can deliver the success criteria and the project goals as milestones in gitlab, we corrected this later on. - Conduct a risk assessment: A.7.9 - Contact expert via e-mail: Contacted at 21.02.26, response 03.03.26, invited to next checkpoint meeting 05.03.26, the expert takes part at the meeting every two weeks

Add slides if we can reproduce them

Table A.14.: Meeting Notes: Checkpoint 1

A.8.2. Checkpoint Meeting 2: 05.03.26

Add slides if we can reproduce them

Participants	Hj. Wenger (Instructor), Urs Keller (Expert), Frank Gauss, Lukas von Allmen
Agenda	- Review of the project goals as milestones and project planning. - Review of risk assessment. - Discussion on the investigation and analysis of network communication between end devices and external networks (RED scenario: sniffing, filtering, and potential data exfiltration).
Decisions	- Variant 1 was selected for further development. - Open questions remain regarding the use and management of AI tokens.
Notes	- We misunderstood how to deliver the project goals and success criteria: Instead of defining the goals as milestone we added a goal section in the thesis. - Discussion on the rationale behind selecting Variant 1. - Consideration of whether a user interface is required when MCP functionality is available - Open Research Question. - NSAK integrates AI capabilities. - The development of a Web GUI is currently considered lower priority - suggestion of Urs Keller.
Tasks	- Send the slides of the final presentation and documentation of "Project 2" to Urs Keller (Expert): "Done" (via E-Mail). - Delivery the projects goals with a detailed description as part of the thesis by Saturday, 07.03.26: "Done" 1.3 - Finalize the project planning: "Done" A.6 - Write the first few chapters of the thesis: "Done"

Table A.15.: Meeting Notes: Checkpoint 2

A.8.3. Checkpoint Meeting 3: 19.03.26

Participants	Hj. Wenger (Instructor), Urs Keller (Expert), Frank Gauss, Lukas von Allmen
Agenda	- Review Project Management and Roadmap - Review of the active milestones (Framework Comparison, AI-Research, Configuration Management) - Discuss Variant Decisions: AI-Integration - Ask about AI token usage - Ask about repository access
Decisions	- We will proceed using NSAK as the basis for our thesis. - Open questions remain regarding the use and management of AI tokens.
Notes	- -
Tasks	- Document decision that we will continue to work with the NSAK framework: 2.2.3 - Expand on variant decision for AI-Integration: - Split diagram into 2 variants: - Expand in detail how the variants are working (e.g., sequence diagram): A.14 and A.16 - Configuration management: Move metadata and others below the device node: "Done" 5.1.2 - BFH TI: Has a cluster with studio macs for AI usage -> Ask if we can use them (https://mlmp.ti.bfh.ch/ via VPN)

Table A.16.: Meeting Notes: Checkpoint 3

A.8.4. Checkpoint Meeting 4: 02.04.26

Participants	Hj. Wenger (Instructor), Urs Keller (Expert), Frank Gauss, Lukas von Allmen
Agenda	- Overview Roadmap and active milestones - Reproducible Test Environment: Introduce ContainerLab, Show diagram, Physical Implementation (could) - AI Scenario: Demo AI-agent connection to self-hosted, LangChain Research LLM - Review MCP Sequence Diagrams - Discuss what needs to be added to the main document and what to the appendix - Ask if it's possible to lend more HW for physical test setup - Ask for access to BFH AI Cluster
Decisions	- -
Notes	- - Alternative to container LAB: Cisco - DNS3 (not open source) - It would be interesting to add more services to the DMZ in the reproducible test environment - Tutor: The current structure is preferred, we should also ask the expert -
Tasks	- Ask for access to BFH AI: https://mlmp.ti.bfh.ch (Requires VPN) - If we are not allowed, ask tutor for guidance - Variant decisions: Add pros/cons and elaborate why we choose a variant - AI-agent: Design and implement logging - Ask the expert about the preferred document structure: Thesis vs Appendix - Create a HW list for tutor, date and configuration (must be planned, device configuration could be done by assistants) -

Table A.17.: Meeting Notes: Checkpoint 4

A.8.5. Checkpoint Meeting 5: 16.04.26

A.8.6. Checkpoint Meeting 6: 30.04.26

A.8.7. Checkpoint Meeting 7: 14.05.26

A.8.8. Checkpoint Meeting 8: 28.05.26

A.8.9. Checkpoint Meeting 9: 11.06.26

Variant 1: AI Purple Team

	Research	Framework	Scenarios (Red- and Blue-Team)	
Must	Framework Comparison	Configuration Management WEB GUI	AI Scenario Red Team AI Scenario Blue Team	Intrusion Detection Blue Team Network Discovery Red Team
Should		Framework Improvements		
Could	GAP Analysis			

Figure A.11.: Variant 1: AI vs Manually Built Scenarios

A.9. Variant Decision: Thesis Goals

During the first sprint of the project, which was focused on project management and planning, we identified the very promising hypothesis that red and blue team activities could be automated and/or enhanced by AI. Pursuing this hypothesis would change the projects focus and goals and thus requires the agreement and approval of the stakeholder. To communicate this circumstance efficiently and leave the option to go with the status quo, we prepared two options to conduct a “Variant Decision”. In the following two subsections the two variants presented in the second checkpoint meeting [A.15](#) are described and illustrated. It must be noted, that the variants and their visualizations [A.11](#) [A.12](#) are momentary snapshots and will not be updated for traceability reasons. For example, the Web GUI was already deprioritized during the discussion of the variants, which is reflected in the project goals [1.3](#) but not here.

A.9.1. Variant 1: AI vs Manually Built Scenarios

Figure [A.11](#) shows the project goals adjusted for the AI focused hypothesis, which is favored variant of the project team. In this option most of the evaluated scenarios will not be realized in favor of AI based scenarios, which also requires additional research [1.3.1](#). The basic idea is to implement scenarios for network discovery [1.3.3](#), intrusion detection [1.3.3](#) and an AI based scenario with the same capabilities [1.3.3](#). In the evaluation of the thesis we can then assess the quality of the AI based scenarios itself [1.3.4](#) and in comparison to the manually built scenarios [1.3.4](#).

Variant 2

	Research	Framework	Scenarios (Red- and Blue-Team)	
Must	Framework Comparison	Configuration Management WEB GUI	Traffic Capture and Exfiltration Red Team	Intrusion Detection Blue Team Network Discovery/ Red Team
Should		Framework Improvements	TLS Downgrade POODLE Red Team	
Could	GAP Analysis		Honeypot Blue Team	

Figure A.12.: Variant 2: Multiple Blue and Red Team Scenarios

A.9.2. Variant 2: Multiple Blue and Red Team Scenarios (Status Quo)

This is the fallback if the other option [A.9.1](#) is not approved by the stakeholders. Even if the project team does not favor this more conservative variant, it still represents a valid way to conduct an interesting project. As illustrated below [A.12](#), in this variant we propose to proceed with the previously planned scenarios for which we already conducted “User Story Mappings” documented under the workshops section [A.11](#). The focus would lie in more conventional scenarios, overall framework improvements and an in depth comparison with another framework in form of a GAP Analysis.

A.9.3. Decision

The stakeholders and project team decided in favor of **Variant 1: AI vs Manually Built Scenarios** [A.9.1](#) in the checkpoint meeting [A.15](#).

A.10. Variant Decision: AI Integration

During the AI-research 2.2 we identified two interesting ways to allow NSAK to interact with AI based technologies. As illustrated in A.13, the first variant purposes to implement an AI-agent directly into the framework and use it in scenarios and drills. In the second variant shown in A.15, the capabilities of NSAK and other relevant tools on the NSAK device would be exposed via MCP.

A.10.1. Variant 1: AI-agent in NSAK

Variant 1: AI-agent in NSAK

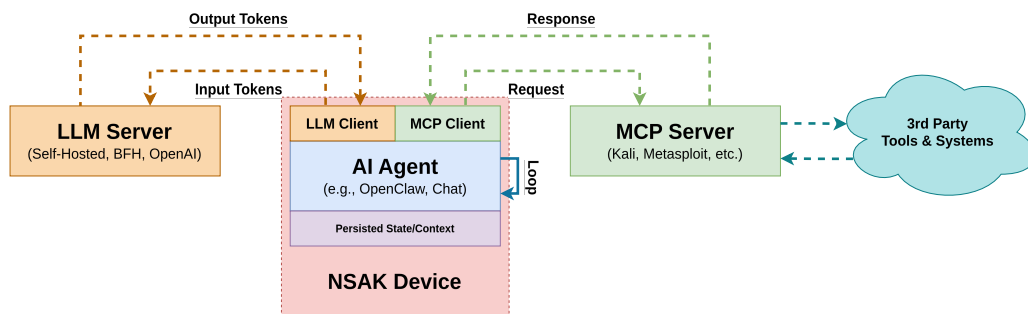


Figure A.13.: AI Integration Variant 1: AI-agent in NSAK

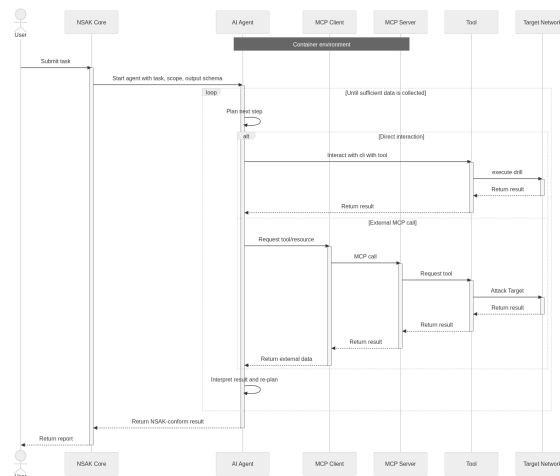


Figure A.14.: Variant 1, AI Agent in NSAK

In this architecture, the AI agent is embedded within the NSAK device. The NSAK core establishes the operational guardrails and schema, and provides the initial

prompt to the AI Agent. The agent uses a local or remote LLM, which is accessible over the management network. It operates within an iterative loop, in which it may either invoke external tools via a command-line interface (e.g., nmap, Metasploit) or interact with them through an MCP server interface. The results of these operations are subsequently processed and returned to the NSAK core in a structured schema-compliant format.

A.10.2. Variant 2: NSAK as MCP Server

Variant 2: NSAK as MCP Server

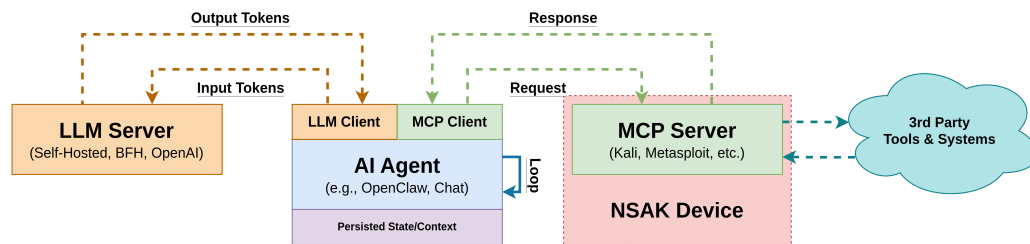


Figure A.15.: AI Integration Variant 2: NSAK as MCP server

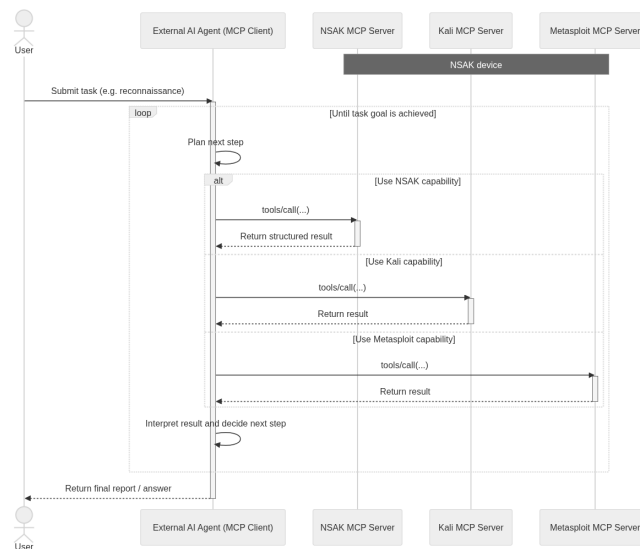


Figure A.16.: Variant 2 NSAK MCP Server

Variant 1, in which the Agentic-AI is embedded within the NSAK device, enables the definition and enforcement of schemas and security policies within a controlled environment. Furthermore, it allows direct interaction with tools via the

command-line interface and integration with MCP servers. This results in a tightly coupled architecture with high control and consistency.

In contrast, Variant 2 relies on an external agent that accesses the NSAK device through an exposed MCP server interface. While this approach provides increased modularity, it also introduces limitations in flexibility, as the agent is restricted to the set of tools exposed by the NSAK device.

From a holistic and multi-layered architectural perspective, Variant 1 is preferred. It enables deeper system integration, higher security, and a wider range of executable tools.

A.10.3. Decision

The project team decided in favor of **Variant 1: AI-agent in NSAK** [A.10.1](#), as it promises to greatly increase the capabilities of NSAK regarding autonomy and automation.

enhance the decision with technical background

This is not correct anymore: we use LangChain Tools instead of MCP for tool calling, which is their own abstraction over vendor specific APIs

A.11. Workshops

In the Project Management phase, several workshops were conducted, including a brainstorming session using Post-it notes and a User Story Mapping exercise on a whiteboard. The goal of these workshops was to clarify the scenarios a network edge device should support.

Following these workshops, the insights gathered were used to derive issues and goals, which were then mapped to detailed milestones in GitLab. All deliverables were categorized using the MoSCoW prioritization method into must, should, and could requirements. An example of this prioritization and scenario mapping is illustrated in Figure A.19. All Milestones links are provided in the URL at the top of the section.

A.11.1. Brainstorm Scenario Selection

In this workshop, participants brainstorm and cluster potential red and blue team scenarios for practical cybersecurity exercises.



Figure A.17.: Brainstorm Scenarios

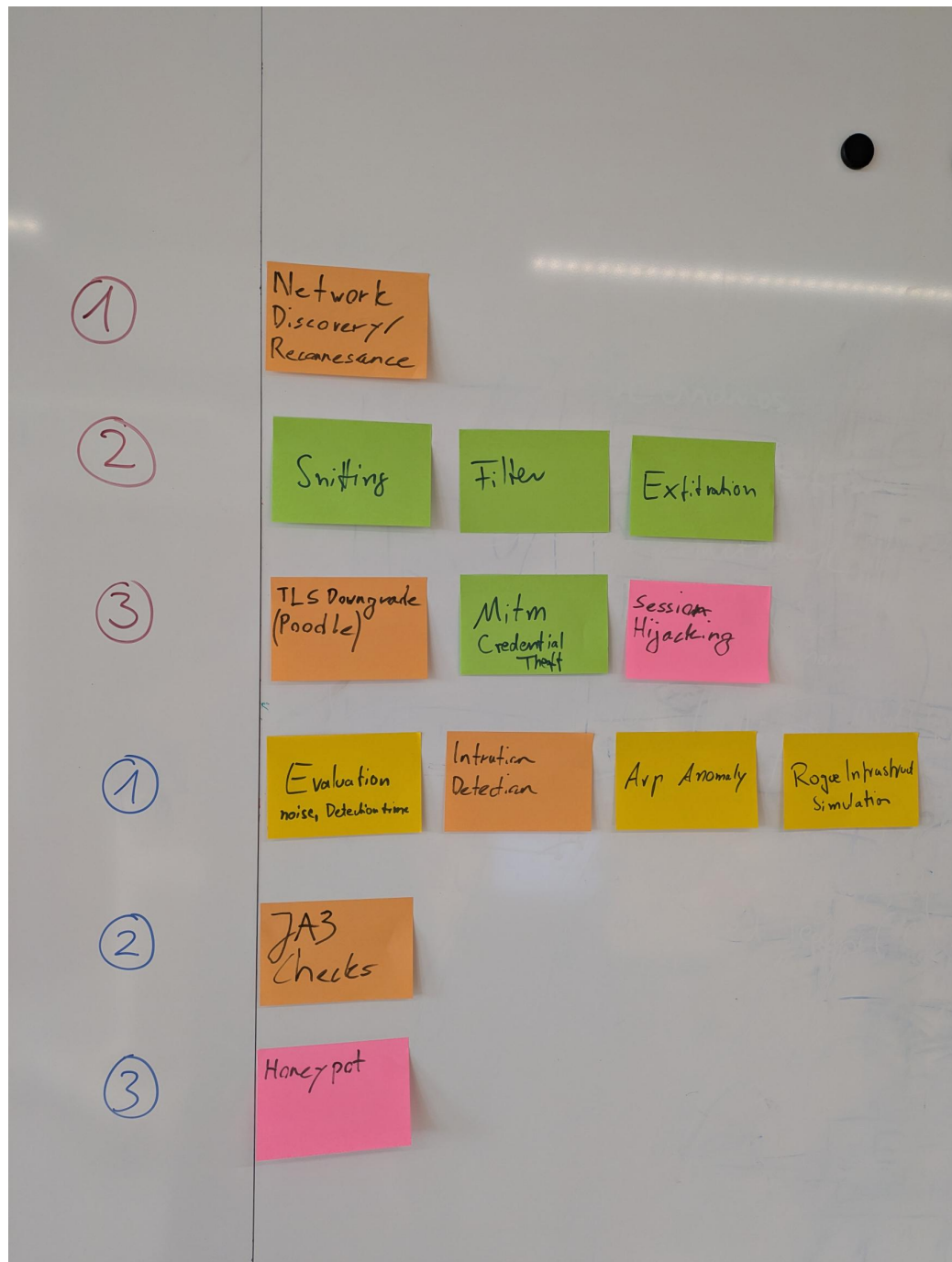


Figure A.18.: Clustering possible Scenarios

The Brainstorm session is used to derive further red/blue team scenarios and led to the pivot of AI-enabled Nsac scenario.

A.11.2. NSAK Scenario: Network Discovery - Red Team

Network Discovery Scenario

Objectives

This workshop aims to evaluate the different steps of the network discovery process and to help participants understand how attackers identify and map potential targets within a network.

Building on this objective, Red Teams consider network discovery one of the most essential activities during the reconnaissance phase, as it helps them identify hosts and services and evaluate potential targets. Once a network map is created, the team can use it in later phases. For example, they might execute an ARP spoofing attack, which allows them to intercept network traffic more efficiently.

In relation to these activities, this scenario addresses the following point from the thesis proposal:

‘Unterstützung typischer Vorgehensweisen aus dem Red-Team- und Penetration-Testing-Bereich, etwa durch Scan- oder Angriffssimulationen.’

The workshop led to the milestone *NSAK Scenario: Network Discovery – Red Team (must)*, in which each step for discovering and mapping a network is documented and structured for later implementation.

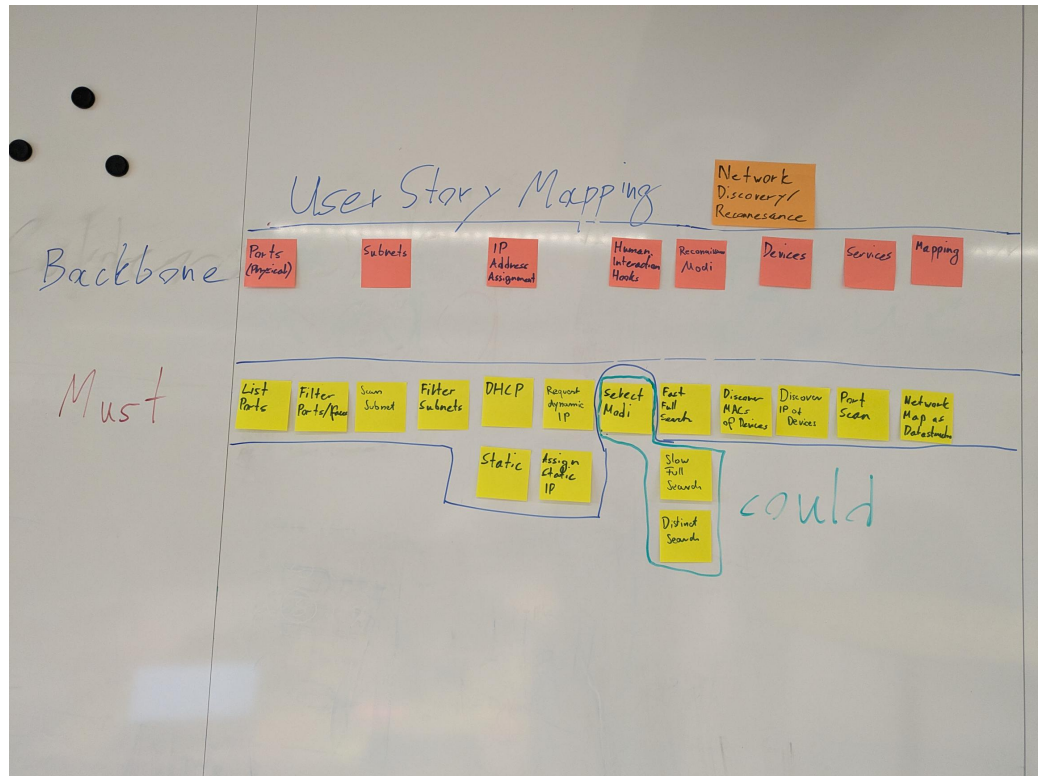


Figure A.19.: NSAK Scenario: Network Discovery - Red Team

A.11.3. NSAK Scenario: TLS Downgrade Poodle - Red Team

TLS Downgrade Poodle Milestone

Objectives

This workshop demonstrates how attackers can exploit TLS downgrade vulnerabilities, such as POODLE, to intercept encrypted communication.

In this scenario, the infamous POODLE attack is implemented, in which a malicious actor tries to convince a client and a server to use the vulnerable TLS version 1.1 instead of 1.2 or 1.3 to encrypt HTTP traffic. This attack requires the attacker to sit between the client and the server (a man-in-the-middle, or MITM), allowing them to intercept and control the traffic. When the client initiates a TLS handshake, the attacker drops packets to the server and sends TCP reset packets to the client, eventually trying older TLS versions. Because TLS 1.1 is vulnerable to a CBC Padding attack, it is possible to create a padding oracle that gradually decrypts the cookie and hijacks the user's session.

Building on this, the scenario directly addresses the following aspect from the

thesis proposal:

‘Unterstützung typischer Vorgehensweisen aus dem Red-Team- und Penetration-Testing-Bereich, etwa durch Scan- oder Angriffssimulationen’

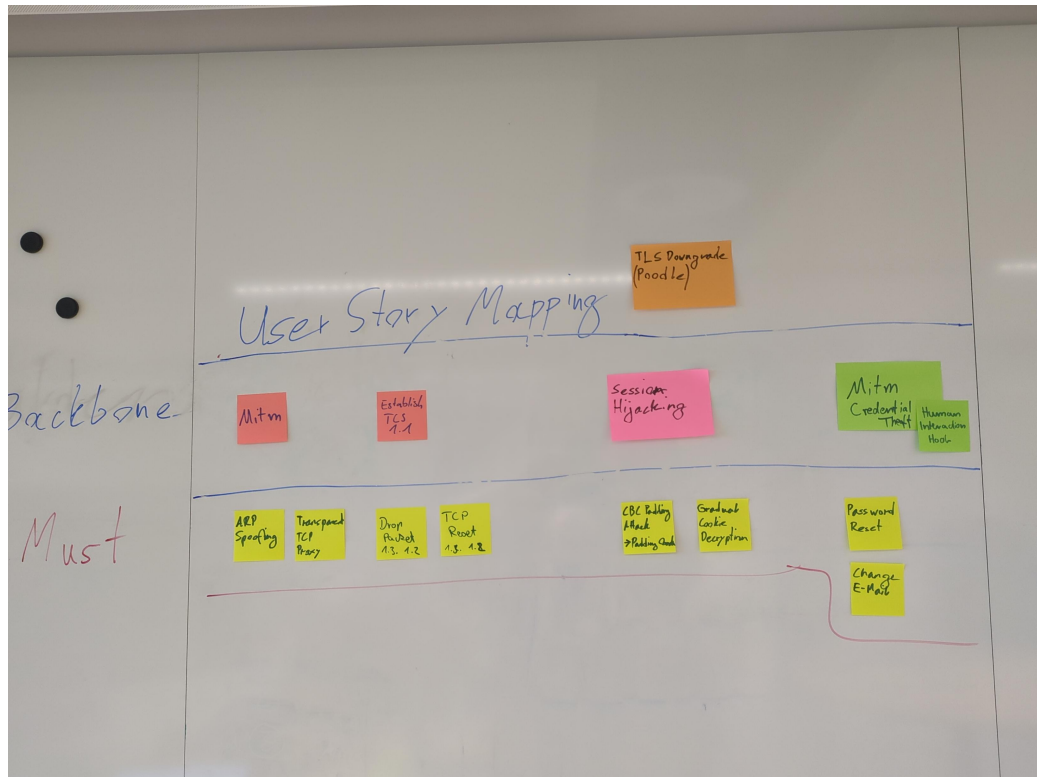


Figure A.20.: NSAK Scenario: TLS Downgrade Poodle - Red Team

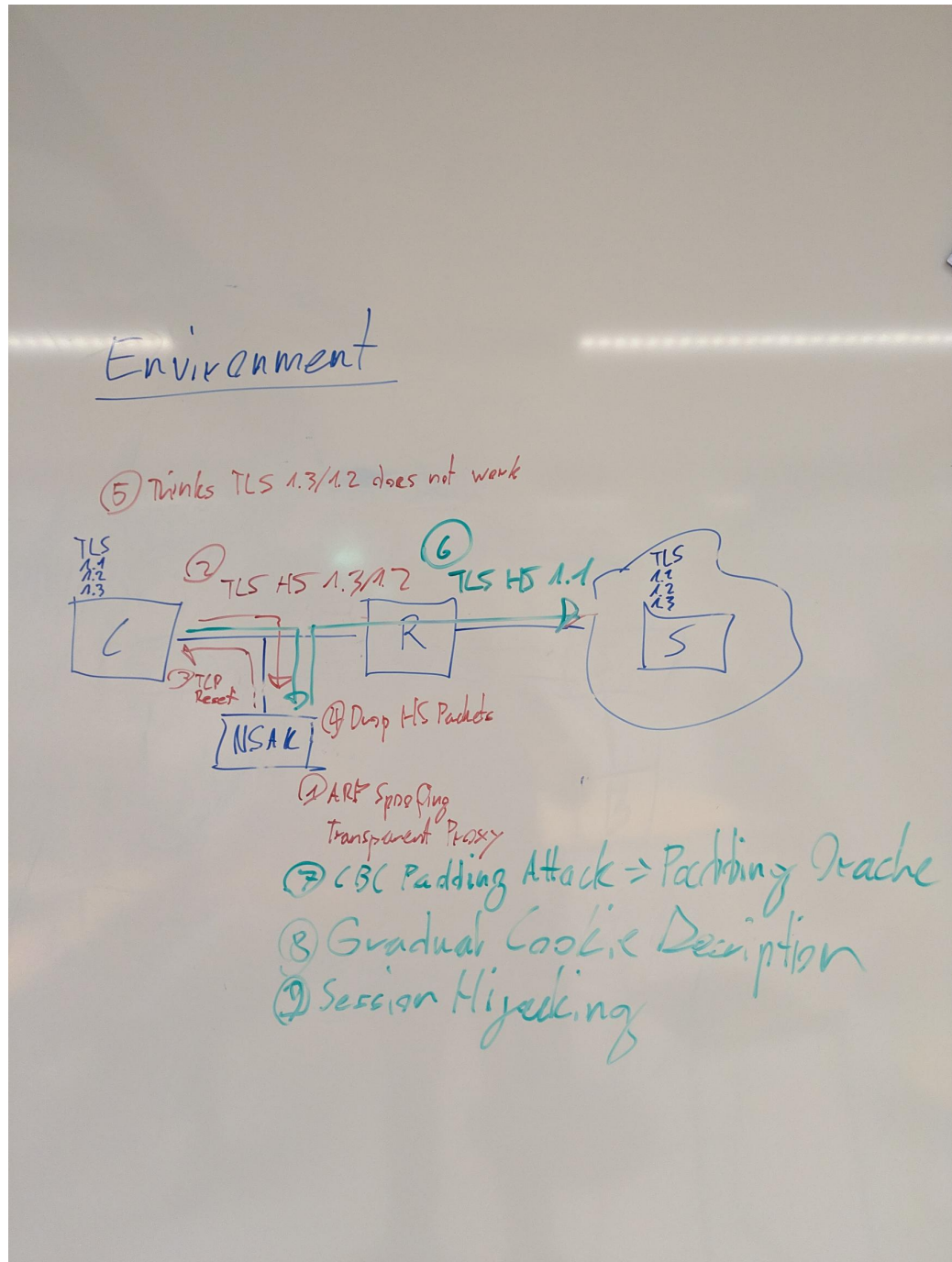


Figure A.21.: NSAK Scenario: TLS Downgrade Poodle -Topology

A.11.4. NSAK Scenario: Honeytrap - Blue Team

Honeytrap Milestone

Honeytraps can serve as an additional form of intrusion detection and help Blue Teams detect attackers in a network. The system tries to attract malicious actors by providing an attack surface as large as possible; a simple way to achieve this is to open ports. After an attacker tries to connect to any of the open ports, the system notifies an operator and may close all open ports to prevent further attempts to compromise the Honeytrap. The operator can then manually intervene to identify and isolate the attacker and analyze the captured payload.

This scenario covers the following bullet point from the thesis proposal:
 ‘Bereitstellung von Funktionen zur Erkennung, Protokollierung und Analyse verdächtiger Aktivitäten als Teil defensiver Massnahmen’

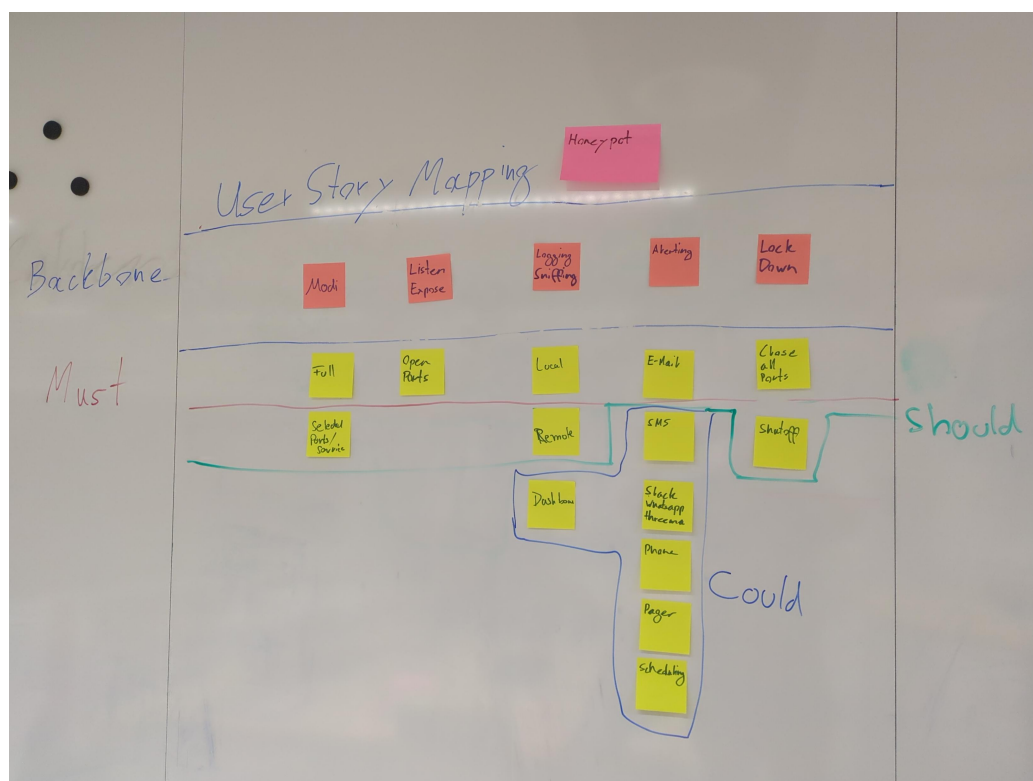


Figure A.22.: NSAK Scenario: Honeytrap - Blue Team

A.11.5. NSAK Scenario: Traffic Capture - Red Team

Traffic Capture Milestone

Capturing, exfiltrating, and analyzing traffic from a targeted network is a key

automated measures may be initiated, and security engineers will be automatically alerted for manual intervention.

This scenario covers the following bullet point from the thesis proposal: “Bereitstellung von Funktionen zur Erkennung, Protokollierung und Analyse verdächtiger Aktivitäten als Teil defensiver Massnahmen”

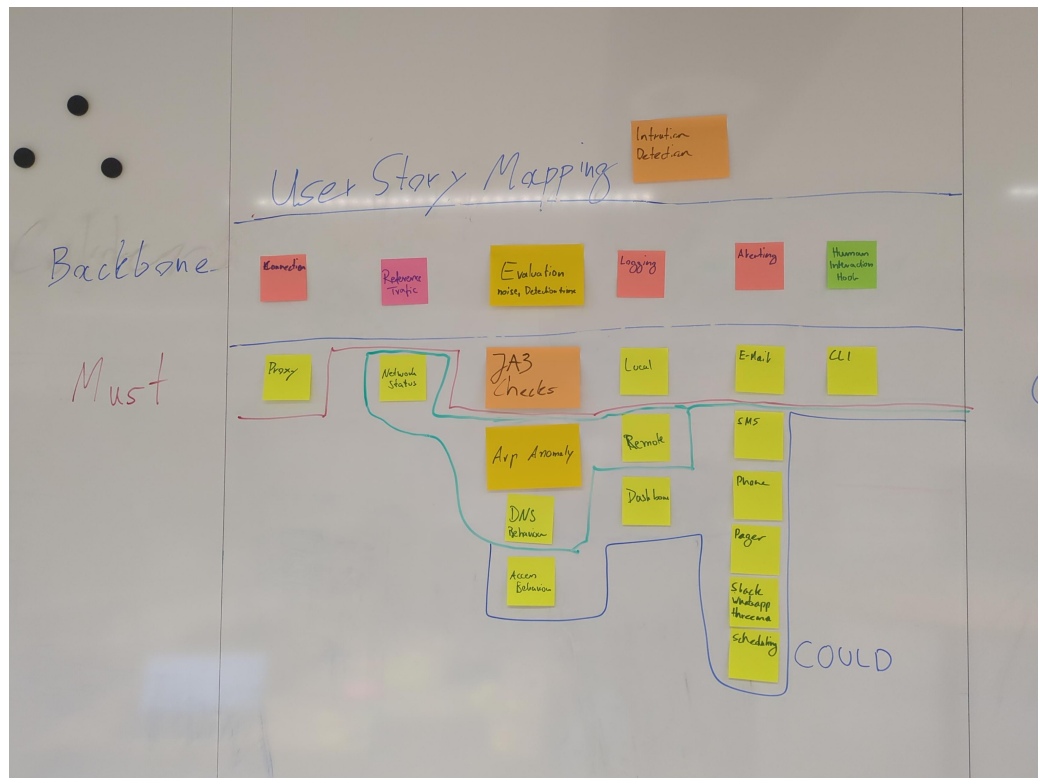


Figure A.24.: NSAK Scenario: Intrusion Detection - Blue Team

A.12. Self-Hosted LLM

During the risk assessment [A.7.9](#) we identified that the AI tokens required to use cloud based LLMs might be very expensive, and it's really hard to estimate the costs. One of the possibilities to avoid this risk was the usage of self-hosted LLMs, and luckily we already had existing hardware at home which is suitable for running smaller LLMs. Besides eliminating the costs for AI tokens, at least during the development phase, it also allows the quick evaluation of different AI Models. Depending on the quality and performance of the smaller models running in the self-hosted setup we can consider not using a cloud based LLM at all.

A.12.1. Hardware Setup

Component	Specification
CPU	AMD Ryzen 5 3600 (6 cores / 12 threads, up to 4.2 GHz)
GPU	NVIDIA GeForce RTX 3070 (8 GB VRAM)
System Memory	32 GB RAM

Table A.18.: Hardware configuration of the self-hosted LLM inference server.

The 8 GB VRAM of the RTX 3070 allows us to run models with up to 7 billion parameters, depending on the specific model [\[22\]](#).

A.12.2. System Setup

The system setup described in [16](#) will configure and expose the Ollama API and OpenWeb UI via NGINX, which provided a chat GUI to interact with Ollama. In contrast to Ollama, which runs directly on the host, the other services are run in containers managed by rootless podman and defined the docker-compose.yml [17](#). The Nginx default.conf [18](#) configures the web server to terminate the SSL connection and act as reverse proxy for the “Open WebUI” and the Ollama API under the directory /llm/.

Services:

- ▶ Ollama: LLM manager, exposing an API for prompts and other interactions (host).
- ▶ Swag: Nginx web server with Certbot for automated SSL certificate generation (containerized).
- ▶ Open WebUI: Web based chat interface for LLM managers (containerized).

```
1 # Login as default user in sudoers or root user
2
3 # Check nvidia driver is loaded and the GPU was correctly
  ↳ detected, otherwise install the according drivers
4 nvidia-smi
5
6 # Install Ollama, podman, podman-compose and enable systemd
  ↳ service
7 sudo pacman -Syu ollama ollama-cuda podman podman-compose
8 sudo systemctl enable --now ollama
9 sudo systemctl status ollama
10
11 # Download and run a qwen coder 7b model for testing
12 ollama pull qwen2.5-coder:7b
13 ollama run qwen2.5-coder
14
15 # Create a new user for isolating the services
16 sudo useradd -m ai
17 sudo passwd ai
18
19 # Enable linger for user ai, required to run services such as
  ↳ rootless containers without being logged in
20 sudo loginctl enable-linger ai
21
22 # Edit the sysctl.conf file
23 sudo vim /etc/sysctl.conf
24
25 # Add the following lines, required for rootless podman to use
  ↳ the ports 443 and 80
26 net.ipv4.ip_unprivileged_port_start=443
27 net.ipv4.ip_unprivileged_port_start=80
28
29 # Load the new config
30 sudo sysctl -p
31
32 # Login as user ai and create the following directory and file
33 mkdir -p .config.containers
34 vim .config/containers/containers.conf
35
36 # Add the following lines, required for rootless podman (podman
  ↳ manages cgroups directly instead of systemd)
37 [engine]
38 cgroup_manager="cgroupfs"
39
40 # Create a docker compose file and add contents from
  ↳ lst:nginx-openwebui-docker-compose.yml
41 vim docker-compose.yml
42
43 # Start the services, so that they create the volume mappings
  ↳ etc, the containers will probably fail for now
44 podman-compose up -d
45 podman-compose down
46
47 # Open the nginx default conf and add the contents from
```

```
1 services:
2   swag:
3     image: lscr.io/linuxserver/swag:latest
4     container_name: swag
5     cap_add:
6       - NET_ADMIN
7     environment:
8       - PUID=1000
9       - PGID=1000
10      - TZ=Europe/Zurich
11      - URL=hiube.ch
12      - VALIDATION=http
13      - SUBDOMAINS=ai,
14      - EMAIL=<my-email>
15      - ONLY_SUBDOMAINS=true
16      - EXTRA_DOMAINS= #optional
17      - STAGING=false #optional
18      - DISABLE_F2B= #optional
19      - SWAG_AUTORELOAD= #optional
20      - SWAG_AUTORELOAD_WATCHLIST= #optional
21     volumes:
22       - /home/ai/swag:/config
23     ports:
24       - 443:443
25       - 80:80 #optional
26       - 443:443/udp #optional
27     restart: unless-stopped
28
29   open-webui:
30     image: ghcr.io/open-webui/open-webui:main
31     container_name: open-webui
32     volumes:
33       - /home/ai/open_webui:/app/backend/data # Use a named
34         ↪ volume for persistence
35     environment:
36       OLLAMA_BASE_URL: http://host.docker.internal:11434
37     restart: always
```

Listing 17: /home/ai/docker-compose.yml

```
1  # redirect all traffic to https
2  server {
3      listen 80 default_server;
4      listen [::]:80 default_server;
5      server_name ai.hiube.ch;
6
7      location / {
8          return 301 https://$host$request_uri;
9      }
10 }
11
12 # main server block
13 server {
14     listen 443 ssl default_server;
15     listen [::]:443 ssl default_server;
16     server_name ai.hiube.ch;
17     include /config/nginx/ssl.conf;
18     root /config/www;
19     index index.html index.htm index.php;
20
21     # enable subfolder method reverse proxy confs
22     # include /config/nginx/proxy-confs/*.subfolder.conf;
23
24     # Reverse proxy for Open WebUI
25     location / {
26         proxy_pass http://open-webui:8080;
27         proxy_set_header Host $host;
28         proxy_set_header X-Real-IP $remote_addr;
29         proxy_set_header X-Forwarded-For
30             ↪ $proxy_add_x_forwarded_for;
31         proxy_set_header X-Forwarded-Proto $scheme;
32         # Required for WebSockets
33         proxy_http_version 1.1;
34         proxy_set_header Upgrade $http_upgrade;
35         proxy_set_header Connection "upgrade";
36         proxy_read_timeout 900s;
37         proxy_send_timeout 900s;
38     }
39
40     # Reverse proxy for Ollama
41     location /llm/ {
42         auth_basic "Restricted Access";
43         auth_basic_user_file /etc/nginx/.htpasswd;
44
45         # If authentication is successful, forward the request
46         ↪ to Ollama
47         # The trailing slash is important, so that ollama does
48         ↪ not see the /llm/ as part of the path!
49         proxy_pass http://host.docker.internal:11434/;
50         proxy_set_header Host $host;
51         proxy_set_header X-Real-IP $remote_addr;
52         proxy_set_header X-Forwarded-For
53             ↪ $proxy_add_x_forwarded_for;
```

System Hardening

It is recommended to put a proper firewall before the services we want to expose to the internet, but for our purposes we can just disable the port forwarding when we don't use the AI. It still makes sense to perform a minimal system hardening as shown in the following listing 19, before exposing the services to the internet.

```
1  # Install UFW
2  sudo pacman -Syu ufw
3  sudo ufw status
4
5  # Allow all outgoing connections
6  sudo ufw default allow outgoing
7
8  # Deny all incoming connections per default
9  sudo ufw default deny incoming
10
11 # Allow SSH for remote access
12 sudo ufw allow ssh
13
14 # Allow HTTP for certbot HTTP challenge
15 sudo ufw allow http
16
17 # Allow HTTPS for Open WebUI
18 sudo ufw allow https
19
20 # Allow default Ollama port
21 sudo ufw allow 11434/tcp
22
23 # Make sure to run this command after adding the "allow" rules!
24 sudo ufw enable
25
26 sudo ufw status
```

Listing 19: UFW configuration

Expose Open WebUI and Ollama

For exposing the services from the home network via HTTPS to the internet, we need a domain name which points to the home router. To achieve this we can use DynDNS, which is provided for free by Infomaniak where the domain “hiube.ch” was registered, and is supported by the FRITZ!Box used in the home network.

The screenshots [A.26](#) and [A.25](#) are showing the respective configurations.

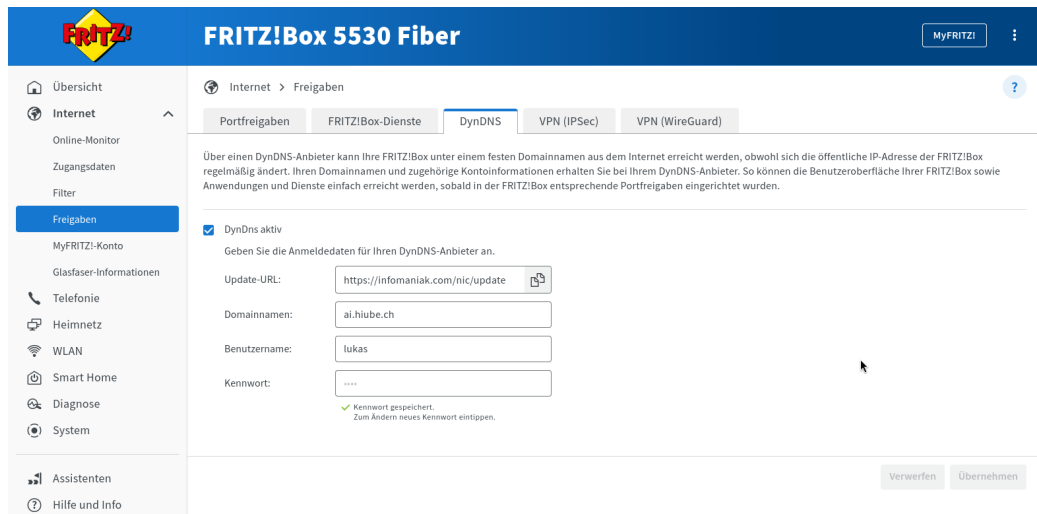


Figure A.25.: FRITZ!Box DynDNS Setup

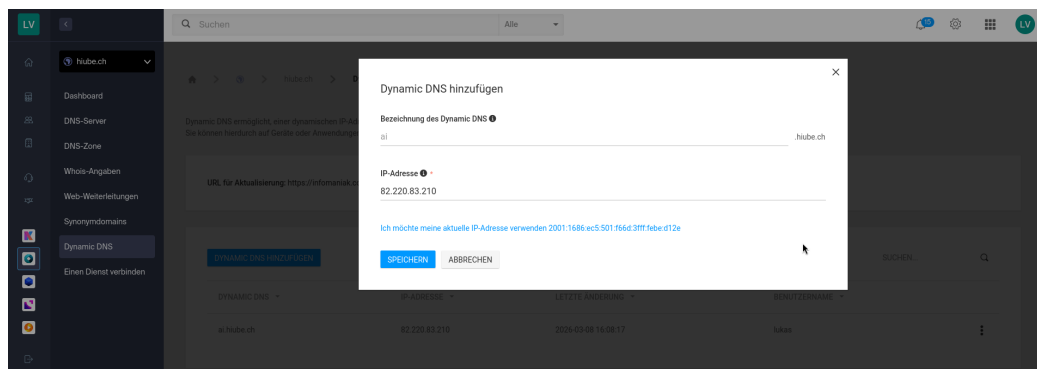


Figure A.26.: Infomaniak DynDNS Setup

Now that the domain name “ai.hiube.ch” points to the router in the home network, we need to redirect the HTTP(S) traffic to the LLM server. This can be achieved with port forwarding rules on the FRITZ!Box, as shown in the screenshot [A.27](#).

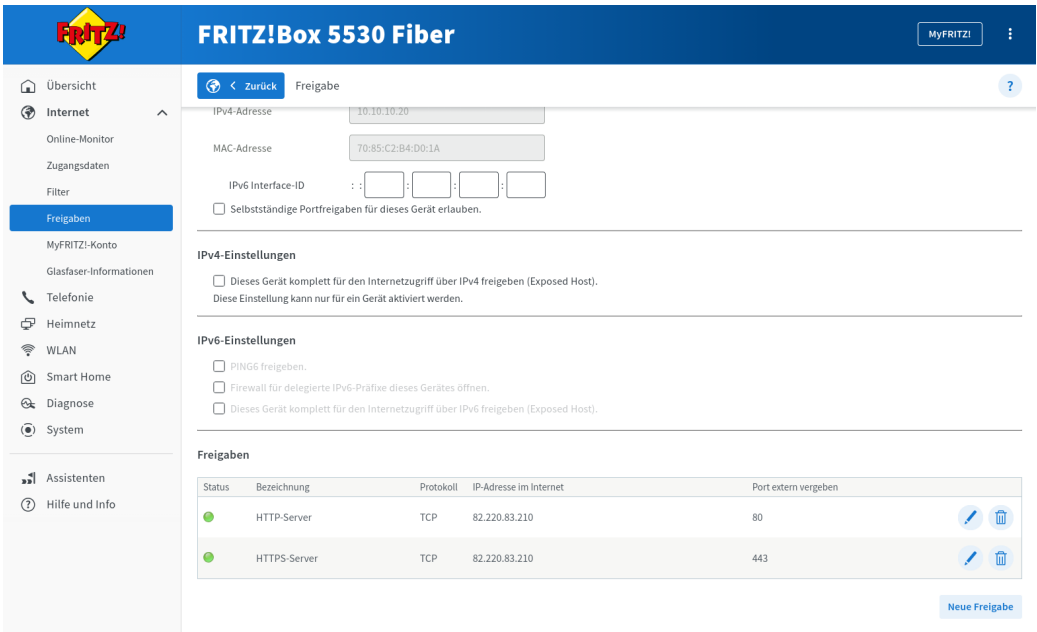


Figure A.27.: FRITZ!Box DynDNS Setup

The Open WebUI and Ollama API should already be reachable via “ai.hiube.ch”, but we will receive a security warning because there is no valid SSL certificate. The easiest way to generate the certificate, is to trigger certbot by restarting the “swag” service as shown in the listing below 20.

- ```
1 # Login as user ai and restart the swag service
2 podman-compose restart swag
```

Listing 20: Restart SWAG Container

### A.12.3. Evaluation

For quickly evaluate models and assess their capabilities we can now use the Open WebUI served under “ai.hiube.ch”. The screenshot A.28 shows a quick test with “qwen2.5-coder:7B”.

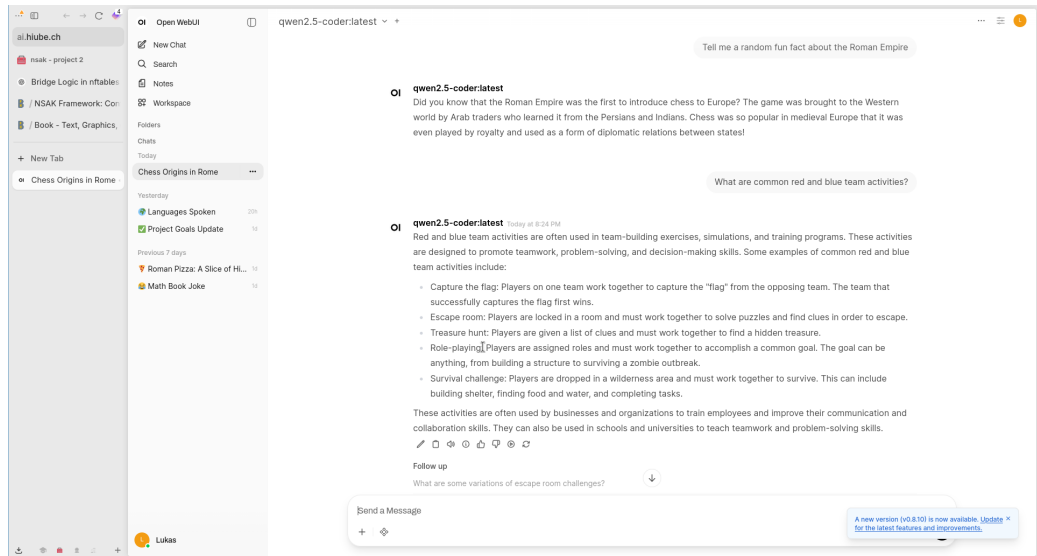


Figure A.28.: FRITZ!Box DynDNS Setup

Later on we can use the Ollama API served under `/llm/` as a backend for AI agents.

### A.13. Writing Quality

Introduced from Professor David Stuckler the PEER-System: Simple and clear academic writing.

The structure is:

- ▶ P 1 POINT just one
- ▶ E Evidence and Example 1-n
- ▶ E Explanation
- ▶ R Repeat linking Links and leads to next topic



## A.14. Test-Environment-Code

### A.14.1. container-lab

---

```
— Firewall (Alpine + nftables) —————
Tri-homed router/firewall: eth1=WAN, eth2=DMZ, eth3=LAN.
All inter-zone traffic is filtered here.
ip_forward enables kernel-level packet routing between interfaces.
firewall:
 kind: linux
 image: alpine:3.19
 cmd: tail -f /dev/null
 cap-add:
 - NET_ADMIN
 sysctls:
 net.ipv4.ip_forward: 1 # required to forward packets between interfaces
 exec:
 - apk add --no-cache nftables iproute2
 - ip addr add 10.0.1.1/24 dev eth1
 - ip addr add 172.16.1.1/24 dev eth2
 - ip addr add 192.168.10.1/24 dev eth3
 - ip route replace default via 10.0.1.254
 # Default FORWARD policy: drop everything not explicitly allowed
 - nft add table inet filter
 - sh -c "nft add chain inet filter forward '{ type filter hook forward priority 0; policy drop; }'"
 # Allow return traffic for already-established connections (stateful firewall)
 - nft add rule inet filter forward ct state established,related accept
 # WAN → DMZ: only HTTP/HTTPS and DNS to dmz-server
 - sh -c "nft add rule inet filter forward iifname eth1 oifname eth2 ip daddr 172.16.1.10 tcp dport
 ↪ '{ 80, 443 }' accept"
 - nft add rule inet filter forward iifname eth1 oifname eth2 ip daddr 172.16.1.10 udp dport 53
 ↪ accept
 - nft add rule inet filter forward iifname eth1 oifname eth2 ip daddr 172.16.1.10 tcp dport 53
 ↪ accept
 # WAN → LAN: completely blocked (no rules = default DROP applies)
 # DMZ → LAN: completely blocked
 - nft add rule inet filter forward iifname eth2 oifname eth3 drop
 # LAN → DMZ: allowed (internal users browse DMZ services)
 - nft add rule inet filter forward iifname eth3 oifname eth2 accept
 # LAN → WAN: HTTP/HTTPS only, with source NAT (masquerade)
 - sh -c "nft add rule inet filter forward iifname eth3 oifname eth1 tcp dport '{ 80, 443 }' accept"
 # NAT: source masquerade for LAN and DMZ egress to WAN
 - nft add table ip nat
 - sh -c "nft add chain ip nat postrouting '{ type nat hook postrouting priority 100; }'"
 - nft add rule ip nat postrouting ip saddr 192.168.10.0/24 oifname eth1 masquerade
 - nft add rule ip nat postrouting ip saddr 172.16.1.0/24 oifname eth1 masquerade
 # DMZ → WAN: DNS forwarding (dmz-server forwards unknown queries to 8.8.8.8)
 - nft add rule inet filter forward iifname eth2 oifname eth1 udp dport 53 accept
 - nft add rule inet filter forward iifname eth2 oifname eth1 tcp dport 53 accept
```

---

Listing 21: Firewall

Listing 21 shows the nf-tables rules set for segmentation of wan, dmz and lan.

---

```

DMZ Nodes (172.16.1.0/24)

— DMZ: Combined Web + DNS Server —
Single DMZ node running both nginx (web) and BIND9 (DNS).
Merging saves a device slot while covering two distinct attack surfaces.

Web (nginx):
80/tcp HTTP - corporate landing page, /robots.txt, /api/v1/status
443/tcp HTTPS - self-signed cert: CN=dmz-server.lab.local
Recon: Server header leaks version; /robots.txt disallows /admin /backup

DNS (BIND9):
53/udp+tcp queries and zone transfer
AXFR intentionally open (misconfiguration) - reveals all internal IPs
Recon: dig @172.16.1.10 lab.local AXFR -> full zone dump
dmz-server:
 kind: linux
 image: alpine:3.19
 cmd: tail -f /dev/null
 cap-add:
 - NET_ADMIN
 binds:
 - scripts/dmz-web-server:/dmz-web-server:ro
 exec:
 - apk add --no-cache nginx bind bind-tools iproute2 openssl python3
 - ip addr add 172.16.1.10/24 dev eth1
 - ip route replace default via 172.16.1.1
 - sh /dmz-web-server/setup.sh
```

---

Listing 22: Web-Server and DNS

Listing 22 shows a web server and DNS server node in the Containerlab YAML configuration. This node is located in the demilitarized zone (DMZ) of the network.

---

```
#
LAN Nodes (192.168.10.0/24)
#

— LAN: Internal Server (Samba + LDAP + SSH) —
Combines Domain Controller and File Server into one node.
Samba provides SMB shares; OpenLDAP provides a lightweight directory.
No full AD provisioning – covers the same recon/attack surface at less cost.
#
22/tcp SSH (admin / Password123!)
139/tcp NetBIOS (Samba)
389/tcp LDAP – anonymous base read: DC=lab,DC=local (user list exposed)
445/tcp SMB – shares: public (anon read), finance (auth), it (auth)
#
Recon:
smbclient -L //192.168.10.5 -N → lists all shares
smbmap -H 192.168.10.5 → share names + permissions
ldapsearch -x -H ldap://192.168.10.5 → user list, group memberships
ctrl-server:
kind: linux
image: alpine:3.19
cmd: tail -f /dev/null
cap-add:
- NET_ADMIN
- SYS_ADMIN # needed for Samba AD provisioning
binds:
- scripts/ctrl-file-server:/ctrl-file-server:ro
exec:
- apk add --no-cache samba openldap openldap-back-mdb openldap-clients openssh iproute2
- ip addr add 192.168.10.5/24 dev eth1
- ip route replace default via 192.168.10.1
- sh -c 'echo "nameserver 172.16.1.10" > /etc/resolv.conf'
- sh /ctrl-file-server/server_setup.sh
```

---

Listing 23: File Server and Domain Control

The LAN segment consists of four nodes, as shown in the following code snippets.

```
— LAN: Workstation alice (Finance dept, user: asmith) —————
Simulates a Finance department workstation.
Sensitive documents on disk; drive mappings reveal share paths.
#
22/tcp SSH (asmith / Password123!)
445/tcp SMB (Samba standalone)
#
Recon:
SSH banner leaks org name and policy
/home/asmith/Documents/Q3_Finance.txt – confidential data (post-exploit)
/home/asmith/Desktop/drive_mappings.txt – reveals \\ctrl-server\finance path
alice:
 kind: linux
 image: alpine:3.19
 cmd: tail -f /dev/null
 cap-add:
 - NET_ADMIN
 exec:
 - apk add --no-cache openssh samba iproute2
 - ip addr add 192.168.10.100/24 dev eth1
 - ip route replace default via 192.168.10.1
 - sh -c 'echo "nameserver 172.16.1.10" > /etc/resolv.conf'
 - ssh-keygen -A
 - sh -c 'echo "PasswordAuthentication yes" >> /etc/ssh/sshd_config'
 - sh -c 'printf "NSAK-Enterprise - Authorized Access Only\nThis system is monitored.\n" >
 ↪ /etc/ssh/banner.txt'
 - sh -c 'echo "Banner /etc/ssh/banner.txt" >> /etc/ssh/sshd_config'
 - adduser -D -s /bin/sh asmith
 - sh -c 'echo "asmith:Password123!" | chpasswd'
 - mkdir -p /home/asmith/Documents /home/asmith/Desktop
 - sh -c 'echo "Q3 2024 Finance Report - CONFIDENTIAL" > /home/asmith/Documents/Q3_Finance.txt'
 - sh -c 'printf "DOMAIN=LAB\nUSER=asmith\nSHARE=\\\\\\\\\\\\\\\\ctrl-server\\\\\\\\finance\n" >
 ↪ /home/asmith/Desktop/drive_mappings.txt'
 - /usr/sbin/sshd

— LAN: Workstation bob (IT dept, user: bjones) —————
Simulates an IT department workstation.
bjones has elevated rights – scripts directory reveals full internal topology.
#
22/tcp SSH (bjones / Password123!)
445/tcp SMB (Samba standalone)
#
Recon:
/home/bjones/Scripts/hosts.txt – lists all internal IPs and roles
/home/bjones/Scripts/README.txt – hints at admin access
bob:
 kind: linux
 image: alpine:3.19
 cmd: tail -f /dev/null
 cap-add:
 - NET_ADMIN
 exec:
 - apk add --no-cache openssh samba iproute2
 - ip addr add 192.168.10.101/24 dev eth1
 - ip route replace default via 192.168.10.1
 - sh -c 'echo "nameserver 172.16.1.10" > /etc/resolv.conf'
 - ssh-keygen -A
 - sh -c 'echo "PasswordAuthentication yes" >> /etc/ssh/sshd_config'
 - sh -c 'printf "Acme Corp AG - Authorized Access Only\nThis system is monitored.\n" >
 ↪ /etc/ssh/banner.txt'
 - sh -c 'echo "Banner /etc/ssh/banner.txt" >> /etc/ssh/sshd_config'
 - adduser -D -s /bin/sh bjones
 - sh -c 'echo "bjones:Password123!" | chpasswd'
 - mkdir -p /home/bjones/Documents /home/bjones/Scripts
 - sh -c 'printf "ctrl-server=192.168.10.5\nalice=192.168.10.100\nprinter=192.168.10.50\n" >
 ↪ /home/bjones/Scripts/hosts.txt'
 - sh -c 'echo "# admin tooling – see ctrl-server at 192.168.10.5" >
 ↪ /home/bjones/Scripts/README.txt'
 - /usr/sbin/sshd
```

---

Listing 24: Work-Stations Bob and Alice

```
— LAN: Network Printer (HP-like, intentionally misconfigured) —————
Simulates a typical enterprise network printer – the "forgotten device".
Rarely patched, often misconfigured, rich source of OSINT and lateral movement.
#
80/tcp HTTP – unauthenticated web admin interface
161/udp SNMP – community string "public" (v1/v2c, full device info)
631/tcp IPP – Internet Printing Protocol (job history, no auth)
#
Recon:
snmpwalk -v2c -c public 192.168.10.50 → model, serial, toner, job list, usernames
curl http://192.168.10.50 → unauthenticated admin page, firmware version
curl http://192.168.10.50:631/jobs → print job history reveals internal usernames
printer:
 kind: linux
 image: alpine:3.19
 cmd: tail -f /dev/null
 cap-add:
 - NET_ADMIN
 - NET_BIND_SERVICE # needed to bind to privileged ports 80 and 631
 binds:
 # printer_sim.py serves the web admin UI (port 80) and IPP (port 631)
 - scripts/printer_sim.py:/printer_sim.py:ro
 exec:
 - apk add --no-cache python3 net-snmp iproute2
 - ip addr add 192.168.10.50/24 dev eth1
 - ip route replace default via 192.168.10.1
 - sh -c 'echo "nameserver 172.16.1.10" > /etc/resolv.conf'
 # SNMP with open public community string – intentional misconfiguration
 - sh -c 'printf "rocommunity public\nsysName HP-LaserJet-M428fdw\nsysLocation Server Room\nB2\nsysContact it@lab.local\n" > /etc/snmp/snmpd.conf'
 - sh -c 'snmpd -f -Lo &'
 # Web admin UI (80) and IPP job listener (631)
 - sh -c 'python3 /printer_sim.py > /var/log/printer_sim.log 2>&1 &'
```

---

Listing 25: Printer

Listing ?? illustrates two workstations, Alice and Bob, the printer shown in Listing 25, and the domain controller with Samba file server shown in Listing 23.

```
- ip addr add 172.16.1.200/24 dev eth2
- ip route replace default via 192.168.10.1
- sh -c 'echo "nameserver 172.16.1.10" > /etc/resolv.conf'

links:
WAN segment (WAN 10.0.1.0/24)
- endpoints: ["firewall:eth1", "wan-br:fw1"]
- endpoints: ["external:eth1", "wan-br:ext"]
DMZ segment (172.16.1.0/24)
- endpoints: ["firewall:eth2", "dmz-br:fw2"]
- endpoints: ["dmz-server:eth1", "dmz-br:dmz-serv"]
- endpoints: ["nsak:eth2", "dmz-br:nsak-dmz"]
LAN segment (192.168.10.0/24)
- endpoints: ["firewall:eth3", "lan-br:fw3"]
- endpoints: ["ctrl-server:eth1", "lan-br:ctrl"]
```

---

Listing 26: Links

Listing 26 shows the connection between endpoints over the defined interfaces.



### A.14.2. Flaws and Vulnerabilities

---

```
1 DMZ --- dmz-server (172.16.1.10)
2
3 DNS / BIND9
4 - allow-transfer { any; } --- AXFR (zone transfer) open to everyone
5 - dnssec-validation no --- no DNSSEC validation
6 - Zone contains internal LAN addresses (ctrl, alice, bob, printer)
7
8 Web / nginx
9 - /secret.txt accessible without auth -> returns DB Password:
10 ↪ {flag:exposed-SOS}
11 - Self-signed certificate (CN=dmz-server.vlab.local)
12 ---
13 LAN --- ctrl-server (192.168.10.5)
14
15 LDAP / OpenLDAP
16 - by anonymous read --- anonymous read access to all entries -> user list,
17 ↪ emails, departments
18 - rootpw Password123! stored in plaintext in config
19 - User passwords stored in LDIF: userPassword: Password123!
20 ldapsearch -x -H ldap://192.168.10.5 -b "dc=lab,dc=local"
21
22 SMB / Samba
23 - ntlm auth = yes + lanman auth = yes --- outdated, weak auth protocols
24 - Share public anonymously readable (no auth) -> README.txt hints at bjones
25 - Share finance contains salary and budget data (asmith / Password123!)
26 - Share it contains dc01_build_sheet.txt with full infrastructure details
27 - All passwords: Password123!
28 ---
29 LAN --- alice (192.168.10.100) \& bob (192.168.10.101)
30
31 - SSH password auth enabled, weak password Password123!
32 - SSH banner leaks organisation name
33 - alice: /home/asmith/Documents/Q3_Finance.txt (confidential),
34 ↪ /home/asmith/Desktop/drive_mappings.txt (share paths)
35 - bob: /home/bjones/Scripts/hosts.txt (all internal IPs + roles), README.txt
36 ↪ hints at admin access
37 ---
38 LAN --- printer (192.168.10.50)
39
40 - Port 80: unauthenticated web admin interface, leaks firmware version
41 ↪ (HP-WebServer/2.6.5), serial number, location, contact
42 - Port 631 /jobs: print job history without auth -> reveals usernames
43 ↪ (asmith, bjones, admin) and document names
44 (server_credentials.txt, payroll)
45 - SNMP community string public (v1/v2c) -> snmpwalk exposes full device info
46 ---
47 Firewall policy (intentional gaps)
48
49 - LAN -> DMZ fully open (no port restriction) --- LAN users can reach all
50 ↪ DMZ ports, not just 80/443
51 - DMZ -> WAN: DNS forwarding to 8.8.8.8 allowed -> DNS exfiltration possible
```

---

Listing 27: Introduced Vulnerabilities in the Virtual Enterprise Network